

UNIVERSIDAD MARIANO GÁLVEZ DE GUATEMALA

FACULTAD DE INGENIERÍA EN SISTEMAS DE INFORMACIÓN

PROGRAMA DE POSGRADOS

TAREA INDIVIDUAL

TAREA 2

Autor (es):
Blanco Linares, Romeo Alexander -- rblancol@miumg.edu.gt

Profesor
Rodriguez Minas, César Giovanni

Curso
Seguridad en Aplicaciones – 4 - 2026

Guatemala, 2026

índice de Contenido

1. Introducción 1
   1.1 Objetivo 2
   1.2 Alcance evaluado 2
   1.3 Metodología y herramientas 2
   1.4 Supuestos y limitaciones 2
   1.5 Resumen de resultados 3
2. Levantamiento de arquitectura 4
   2.1 Descripción del sistema 4
   2.2 Arquitectura lógica por capas 4
   2.3 Inventario de componentes 5
   2.4 Inventario de activos de información 6
   2.5 Flujos de información y su criticidad 6
3. Diagramas de flujo de datos (DFD) 8
   3.1 Convenciones 8
   3.2 DFD Nivel 0 – Contexto general 9
   3.3 DFD Nivel 1 – Procesos principales, almacenes y fronteras 10
   3.4 Fronteras de confianza (Trust Boundaries) 11
   3.5 DFD Nivel 2 – Transferencias, middleware e integración bancaria 12
   3.6 Evidencias de Threat Dragon 14
4. Análisis de amenazas mediante STRIDE 15
   4.1 Método 15
   4.2 Catálogo de amenazas identificadas 21
   4.3 Matriz STRIDE consolidada 24
   4.4 Registro de validación técnica 26
5. Priorización de riesgos 27
   5.1 Criterios y escala 27
   5.2 Matriz de riesgos (impacto × probabilidad) 29
   5.3 Ranking de amenazas 30
   5.4 Top 10 de hallazgos prioritarios 32
   5.5 Distribución de riesgos 32
6. Casos de abuso (Abuse Cases) 34
   6.1 Catálogo resumen 34
   6.2 Detalle de los casos de abuso 36
7. Definición de controles de seguridad 43
   7.1 Catálogo de controles 43

7.2 Relación amenaza – control 45
7.3 Riesgos residuales 46
8. Matriz de riesgos y remediación 48
9. Roadmap de mejoras 50
9.1 Corto plazo (0–3 meses) 50
9.2 Mediano plazo (3–6 meses) 50
9.3 Largo plazo (6–12 meses) 51
9.4 Iniciativas transversales del SSDLC 51
10. Criterios de aceptación y control de evidencias 53
11. Conclusiones 54
12. Referencias 55

Índice de Figuras

Figura 1 DFD Nivel 0 – Contexto 9
Figura 2 DFD Nivel 1 10
Figura 3 DFD Nivel 2 – Transferencias y pagos 12
Figura 4 Lista de amenazas generada por Threat Dragon (DFD Nivel 0) 16
Figura 5 Lista de amenazas generada por Threat Dragon (DFD Nivel 1) 17
Figura 6 Lista de amenazas generada por Threat Dragon (DFD Nivel 2) 19

Índice de Tablas

Tabla 1 Arquitectura lógica por capas 4
Tabla 2 Inventario de componentes 5
Tabla 3 Inventario de activos de información 6
Tabla 4 Flujos de información y su criticidad 6
Tabla 5 Fronteras de confianza (Trust Boundaries) 11
Tabla 6 Elementos del DFD Nivel 2 y amenazas relevantes 13
Tabla 7 Flujos de datos del DFD Nivel 2 13
Tabla 8 Aplicabilidad de STRIDE por tipo de elemento 15
Tabla 9 Catálogo de amenazas identificadas 21
Tabla 10 Matriz STRIDE consolidada 24
Tabla 11 Registro de validación técnica 26
Tabla 12 Escala de impacto 27
Tabla 13 Escala de probabilidad 27
Tabla 14 Niveles de riesgo y decisión de tratamiento 27
Tabla 15 Matriz de riesgos (impacto × probabilidad) 29
Tabla 16 Ranking de amenazas 30
Tabla 17 Top 10 de hallazgos prioritarios 32
Tabla 18 Distribución de riesgos por nivel 32
Tabla 19 Catálogo resumen de casos de abuso 34
Tabla 20 Detalle del caso de abuso CA-01 – Toma de cuenta por credential stuffing, phishing o SIM swap 36
Tabla 21 Detalle del caso de abuso CA-02 – Token de acceso forjado o reutilizado 36
Tabla 22 Detalle del caso de abuso CA-03 – Manipulación de monto o cuenta destino en la orden de transferencia 37
Tabla 23 Detalle del caso de abuso CA-04 – Alteración o inyección de mensajes hacia ACH / Core 37
Tabla 24 Detalle del caso de abuso CA-05 – Modificación no autorizada de saldos o transacciones en la BD 38
Tabla 25 Detalle del caso de abuso CA-06 – Negación de operaciones por falta de no repudio 38
Tabla 26 Detalle del caso de abuso CA-07 – Exposición masiva de datos por BOLA / IDOR o SQL injection 39
Tabla 27 Detalle del caso de abuso CA-08 – Compromiso de secretos y claves criptográficas 39
Tabla 28 Detalle del caso de abuso CA-09 – Ingeniería inversa y almacenamiento inseguro en la app móvil 40
Tabla 29 Detalle del caso de abuso CA-10 – Denegación de servicio en login y transferencias 40
Tabla 30 Detalle del caso de abuso CA-11 – Acceso a funciones privilegiadas (BFLA) 40
Tabla 31 Detalle del caso de abuso CA-12 – Abuso de privilegios en el backoffice 41
Tabla 32 Detalle del caso de abuso CA-13 – Compromiso de dependencias de terceros y cadena de suministro 41

Tabla 33 Catálogo de controles de seguridad 43
Tabla 34 Relación amenaza – control 45
Tabla 35 Riesgos residuales por caso de abuso 46
Tabla 36 Matriz de riesgos y remediación 48
Tabla 37 Plan de remediación a corto plazo (0–3 meses) 50
Tabla 38 Plan de remediación a mediano plazo (3–6 meses) 50
Tabla 39 Plan de remediación a largo plazo (6–12 meses) 51
Tabla 40 Criterios de aceptación y control de evidencias 53

1. Introducción

El ecosistema financiero actual exige plataformas de banca digital que garanticen confidencialidad e integridad, haciendo imperativa la adopción de seguridad proactiva desde las fases iniciales del Ciclo de Vida de Desarrollo Seguro de Software (SSDLC). Este informe detalla el modelo de amenazas integral de la plataforma web y móvil de "Banco Ejemplo, S.A.", diseñado para anticipar y documentar vulnerabilidades arquitectónicas antes de llegar a producción.

El análisis se estructuró con OWASP Threat Dragon, construyendo Diagramas de Flujo de Datos (DFD) en niveles 0, 1 y 2. Estos diagramas mapean procesos críticos, almacenes de datos y fronteras de confianza (Trust Boundaries) con terceros como el Core bancario y la red ACH. Sobre esta base lógica, se aplicó exhaustivamente la metodología STRIDE para evaluar y escudriñar la superficie de ataque de cada componente.

Posteriormente, se evaluó el riesgo inherente mediante matrices de Probabilidad e Impacto para priorizar la remediación. Para las amenazas de severidad Crítica y Alta, se modelaron Casos de Abuso (Abuse Cases) que detallan los vectores de ataque y establecen controles preventivos, detectivos y correctivos para reducir el riesgo residual.

Finalmente, el documento culmina con una matriz de remediación y un *roadmap* estratégico. La implementación de estos controles fortalecerá significativamente la postura defensiva de la institución, protegiendo los activos críticos, mitigando el fraude y garantizando el cumplimiento de las normativas de la industria financiera.

1.1 Objetivo

Diseñar y documentar un modelo de amenazas integral para la plataforma de banca digital de Banco Ejemplo, S.A., utilizando OWASP Threat Dragon, con el fin de identificar amenazas potenciales, evaluar riesgos, definir prioridades de remediación y establecer controles de seguridad tempranos dentro del SSDLC.

1.2 Alcance evaluado

El análisis cubre la arquitectura completa de la solución:

- **Componentes de negocio:** autenticación y MFA, consulta de cuentas, transferencias y pagos, notificaciones.
- **Aplicaciones web y móviles:** SPA web y app móvil Android / iOS.
- **APIs y servicios de integración:** WAF, API Gateway y middleware hacia Core bancario y red ACH.
- **Bases de datos:** identidad y sesiones, transaccional, auditoría, cola de mensajes y bóveda de secretos / HSM.
- **Infraestructura asociada:** zonas de red (DMZ, aplicaciones, datos, integración y administración).
- **Flujos de información internos y externos** y **dependencias de terceros** (SMS / Push / Email, KYC / buró, ACH).

1.3 Metodología y herramientas

El trabajo sigue la secuencia vista en la Semana 2 del curso: (1) levantamiento de arquitectura, (2) construcción de DFD con fronteras de confianza, (3) identificación de amenazas con STRIDE por elemento, (4) priorización con la fórmula **Riesgo = Probabilidad × Impacto**, (5) casos de abuso, (6) controles y plan de remediación. La herramienta de modelado es **OWASP Threat Dragon**; la herramienta apoya, estructura y documenta el análisis, pero no sustituye el criterio del especialista.

1.4 Supuestos y limitaciones

- Banco Ejemplo, S.A. es una entidad ilustrativa; la arquitectura refleja un patrón habitual de banca digital y debe confirmarse con el equipo de Arquitectura.

- Impacto y probabilidad se estiman de forma cualitativa con las escalas de la sección 5.1; deben recalibrarse con datos históricos de incidentes de la entidad.
- Se asume que los controles listados como «recomendados» aún no están implementados en su totalidad; el riesgo calculado es **riesgo inherente**, y el riesgo residual se estima en los casos de abuso (sección 6).
- Marco normativo de referencia: lineamientos de riesgo tecnológico de la Superintendencia de Bancos de Guatemala y buenas prácticas OWASP / NIST.

1.5 Resumen de resultados

Se modelaron **30 amenazas** sobre los elementos del DFD: **6 críticas, 7 altas, 15 medias y 2 bajas**. Para las 13 amenazas críticas y altas se documentaron casos de abuso y controles preventivos, detectivos y correctivos. Los hallazgos de mayor prioridad se concentran en la toma de cuentas (T01), la manipulación de transacciones (T03), la exposición masiva de datos por fallas de autorización (T08) y el abuso de privilegios en el backoffice (T14).

2. Levantamiento de arquitectura

2.1 Descripción del sistema

Banco Ejemplo, S.A. ofrece a sus clientes una plataforma de banca digital compuesta por una aplicación web (SPA) y una aplicación móvil. Ambas consumen una capa de APIs publicadas mediante un WAF y un API Gateway en la DMZ. Los servicios de negocio (autenticación, cuentas, transferencias y pagos, notificaciones) operan en una zona de aplicaciones, persisten información en una zona de datos y se integran, mediante un middleware, con el Core bancario y la red ACH para transferencias interbancarias. Proveedores externos prestan los servicios de mensajería y de validación de identidad (KYC / buró). El personal de soporte opera mediante un portal de backoffice ubicado en una red administrativa segregada.

Funciones críticas del negocio: inicio de sesión con MFA, consulta de saldos y movimientos, transferencias propias / a terceros / interbancarias (ACH), pago de servicios, gestión de dispositivos y límites, y enrolamiento con validación KYC.

2.2 Arquitectura lógica por capas

Tabla 1

Arquitectura lógica por capas

Capa / zona	Componentes	Responsabilidad	Controles base esperados
Canales (TB-1)	P1 App Web SPA y App Móvil; E1 Cliente	Interfaz del cliente; captura de credenciales y órdenes	CSP, pinning, protección de la app
Perímetro – DMZ (TB-2)	P2 WAF + API Gateway	Terminación TLS, validación de tokens, rate limiting, enrutamiento	WAF, OAuth 2.0 / OIDC, rate limiting
Aplicaciones (TB-3)	P3 Autenticación, P4 Cuentas, P5 Transferencias, P6 Notificaciones	Lógica de negocio y autorización	RBAC / ABAC, validación, antifraude
Administración (TB-4)	P8 Portal Backoffice; E2 Soporte	Gestión de clientes y casos por personal interno	PAM, MFA, aprobación dual
Datos (TB-5)	D1 Identidad, D2 Transaccional, D3 Auditoría, D4 Bóveda / HSM, D5 Cola	Persistencia, mensajería, auditoría y secretos	Cifrado, privilegios mínimos, DAM
Integración bancaria (TB-6)	P7 Middleware; E6 Core bancario	Orquestación y traducción de mensajes hacia Core y ACH	mTLS, firma de mensajes, HSM
Terceros (TB-7)	E3 SMS / Push / Email; E4 Red ACH; E5 KYC / Buró	Notificaciones, compensación interbancaria, validación de identidad	Contratos y SLA, minimización de datos
Transversal	Logging centralizado, SIEM, alertamiento	Detección y respuesta	Logs inmutables, casos de uso SIEM

Nota. TB = frontera de confianza (Trust Boundary). Elaboración propia.

2.3 Inventario de componentes

Tabla 2

Inventario de componentes

ID	Componente	Tipo	Descripción / tecnología de referencia	Zona
E1	Cliente	Entidad externa	Persona natural o jurídica que opera desde navegador o móvil.	TB-1
E2	Personal de soporte / backoffice	Entidad externa	Empleados que atienden casos y gestionan clientes.	TB-4
E3	Proveedor SMS / Push / Email	Tercero	Envío de OTP y alertas transaccionales por API.	TB-7
E4	Red ACH / Cámara de compensación	Tercero	Compensación de transferencias interbancarias.	TB-7
E5	Proveedor KYC / Buró	Tercero	Validación de identidad y consulta crediticia por API.	TB-7
E6	Core bancario	Sistema interno	Registro contable de cuentas y saldos.	TB-6
P1	App Web SPA / App Móvil	Proceso	SPA (React / Angular) y apps Android / iOS.	TB-1
P2	WAF + API Gateway	Proceso	Filtrado L7, validación de tokens, rate limiting y enrutamiento.	TB-2
P3	Servicio de Autenticación (IAM / MFA)	Proceso	Login, OAuth 2.0 / OIDC, MFA, sesiones y dispositivos de confianza.	TB-3
P4	Servicio de Cuentas y Consultas	Proceso	Saldos, movimientos y datos del cliente (REST).	TB-3
P5	Servicio de Transferencias y Pagos	Proceso	Validación, autorización, antifraude y orquestación de órdenes (ver Nivel 2).	TB-3
P6	Servicio de Notificaciones	Proceso	Generación y envío de OTP y alertas.	TB-3
P7	Middleware de integración	Proceso	Adaptadores hacia Core y ACH; mapeo y firma de mensajes.	TB-6
P8	Portal Backoffice	Proceso	Consola interna de soporte y administración.	TB-4
D1	BD Identidad y Sesiones	Almacén	Credenciales (hash), factores, sesiones y dispositivos.	TB-5
D2	BD Transaccional	Almacén	Cuentas, movimientos y estado de transacciones.	TB-5
D3	Bitácoras de auditoría (SIEM)	Almacén	Eventos de acceso, autenticación y transacciones.	TB-5
D4	Bóveda de secretos / HSM	Almacén	Llaves de firma, secretos y certificados.	TB-5
D5	Cola de mensajes (broker)	Almacén	Órdenes pendientes hacia integración bancaria.	TB-5

Nota. E = entidad externa; P = proceso; D = almacén de datos; TB = frontera de confianza. Elaboración propia.

2.4 Inventario de activos de información

Clasificación: Público, Interno, Confidencial y Restringido. C-I-D indica la criticidad de Confidencialidad, Integridad y Disponibilidad (A = alta, M = media, B = baja).

Tabla 3

Inventario de activos de información

ID	Activo	Descripción / ubicación	Clasificación	C-I-D	Dueño
A1	Credenciales y factores de autenticación	Contraseñas (hash), semillas TOTP, llaves FIDO2 – D1	Restringido	A-A-A	CISO
A2	Tokens de sesión y de acceso	JWT / refresh tokens – P2, P3	Restringido	A-A-M	CISO
A3	Datos personales y KYC	DPI, dirección, teléfono – D1, E5	Confidencial	A-A-M	Cumplimiento
A4	Datos de cuentas y saldos	D2, E6	Confidencial	A-A-A	Líder de Negocio
A5	Órdenes e historial de transacciones	D2, D5, P5	Restringido	M-A-A	Líder de Negocio
A6	Llaves criptográficas y secretos	D4	Restringido	A-A-A	Infraestructura
A7	Bitácoras de auditoría	D3	Confidencial	M-A-M	SOC
A8	Códigos OTP y alertas	P6, E3	Restringido	A-A-M	CISO
A9	Código fuente, configuración y pipeline	Repositorios, CI/CD	Confidencial	A-A-M	Líder de Desarrollo
A10	Disponibilidad de la banca digital	Plataforma completa	Crítico para el negocio	B-M-A	Operaciones TI

Nota. C-I-D = confidencialidad, integridad y disponibilidad (A = alta, M = media, B = baja). Elaboración propia.

2.5 Flujos de información y su criticidad

Tabla 4

Flujos de información y su criticidad

ID	Origen → Destino	Datos transportados	Canal / protocolo	Frontera	Criticidad
F1	E1 → P1	Credenciales, OTP y órdenes del usuario (entrada local)	Interacción local	TB-1	**Alta**
F2	P1 → P2	Peticiones API: login, consultas y órdenes (JSON)	HTTPS / TLS 1.2+	TB-1 → TB-2	**Crítica**
F3	P2 → P3	Credenciales, tokens y solicitudes de MFA	mTLS / REST	TB-2 → TB-3	**Crítica**
F4	P3 ↔ D1	Hash de contraseña, factores y sesiones	TLS / SQL	TB-3 → TB-5	**Crítica**
F5	P2 → P4	Consultas de saldos y movimientos	mTLS / REST	TB-2 → TB-3	**Alta**
F6	P4 ↔ D2	Datos de cuentas y movimientos	TLS / SQL	TB-3 → TB-5	**Alta**
F7	P2 → P5	Orden de transferencia o pago firmada	mTLS / REST	TB-2 → TB-3	**Crítica**
F8	P5 ↔ D2	Registro y estado de la transacción	TLS / SQL	TB-3 → TB-5	**Crítica**
F9	P5 → P7	Orden de débito / crédito	mTLS / cola	TB-3 → TB-6	**Crítica**
F10	P7 ↔ E6	Posteo en el Core y respuesta	mTLS / API del Core	TB-6	**Crítica**

ID	Origen → Destino	Datos transportados	Canal / protocolo	Frontera	Criticidad
F11	P7 ↔ E4	Instrucciones ACH y conciliación	Canal dedicado + firma	TB-6 → TB-7	**Crítica**
F12	P5 → P6	Evento de operación para notificar	Cola / REST interno	TB-3	**Media**
F13	P6 → E3	Mensajes SMS / Push / Email (incluye OTP)	HTTPS API del proveedor	TB-3 → TB-7	**Alta**
F14	P3 → P6	Solicitud de envío de OTP	REST interno	TB-3	**Alta**
F15	P3 ↔ E5	Datos de identidad para KYC	HTTPS API del proveedor	TB-3 → TB-7	**Alta**
F16	E2 → P8	Autenticación y operaciones de soporte	HTTPS vía VPN / bastión	TB-4	**Alta**
F17	P8 → P4	Consulta y gestión de datos de clientes	mTLS / REST	TB-4 → TB-3	**Alta**
F18	P2 → D3	Eventos de acceso (WAF / Gateway)	Syslog TLS	TB-2 → TB-5	**Media**
F19	P3 → D3	Eventos de autenticación	Syslog TLS	TB-3 → TB-5	**Alta**
F20	P5 → D3	Eventos de transacciones	Syslog TLS	TB-3 → TB-5	**Alta**
F21	P3 → D4	Llaves de firma de tokens y secretos	API de bóveda (mTLS)	TB-3 → TB-5	**Crítica**
F22	P7 → D4	Llaves y firmas de mensajes	PKCS#11 / API HSM	TB-6 → TB-5	**Crítica**

Nota. F = flujo de datos; TB = frontera de confianza. Elaboración propia.

3. Diagramas de flujo de datos (DFD)

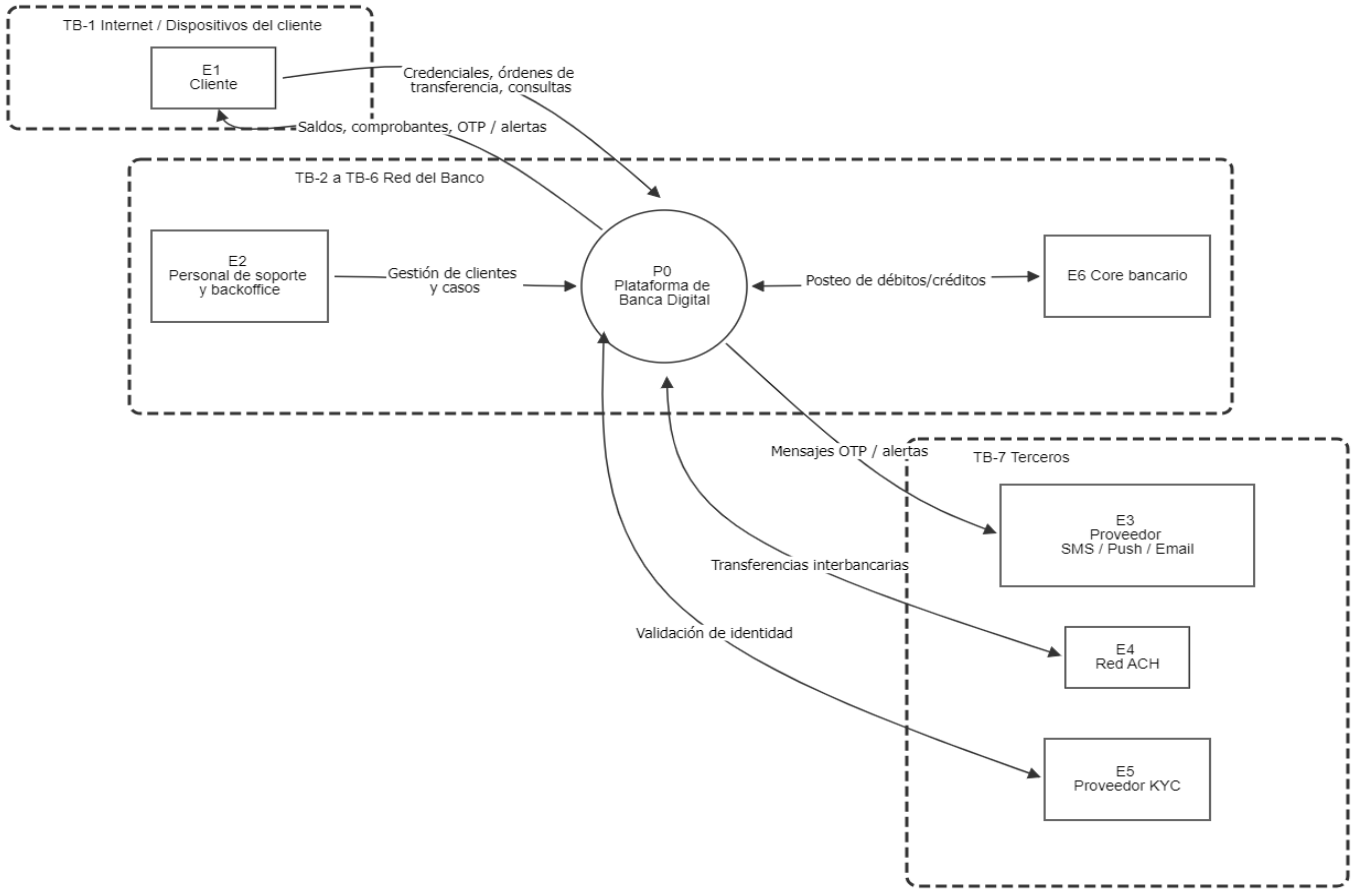
3.1 Convenciones

Los diagramas siguen la notación de OWASP Threat Dragon: entidades externas (rectángulo), procesos (círculo), almacenes de datos (dos líneas paralelas; cilindro en las figuras de referencia), flujos de datos (flechas) y fronteras de confianza (líneas punteadas). Los identificadores (E, P, D, F, TB) son los mismos en todo el documento.

3.2 DFD Nivel 0 – Contexto general

Muestra la plataforma como un único proceso (P0) y sus relaciones con usuarios y sistemas externos: el cliente (usuario externo), el personal de soporte (usuario interno), el Core bancario, la red ACH, el proveedor de mensajería y el proveedor KYC.

Figura 1
DFD Nivel 0 – Contexto

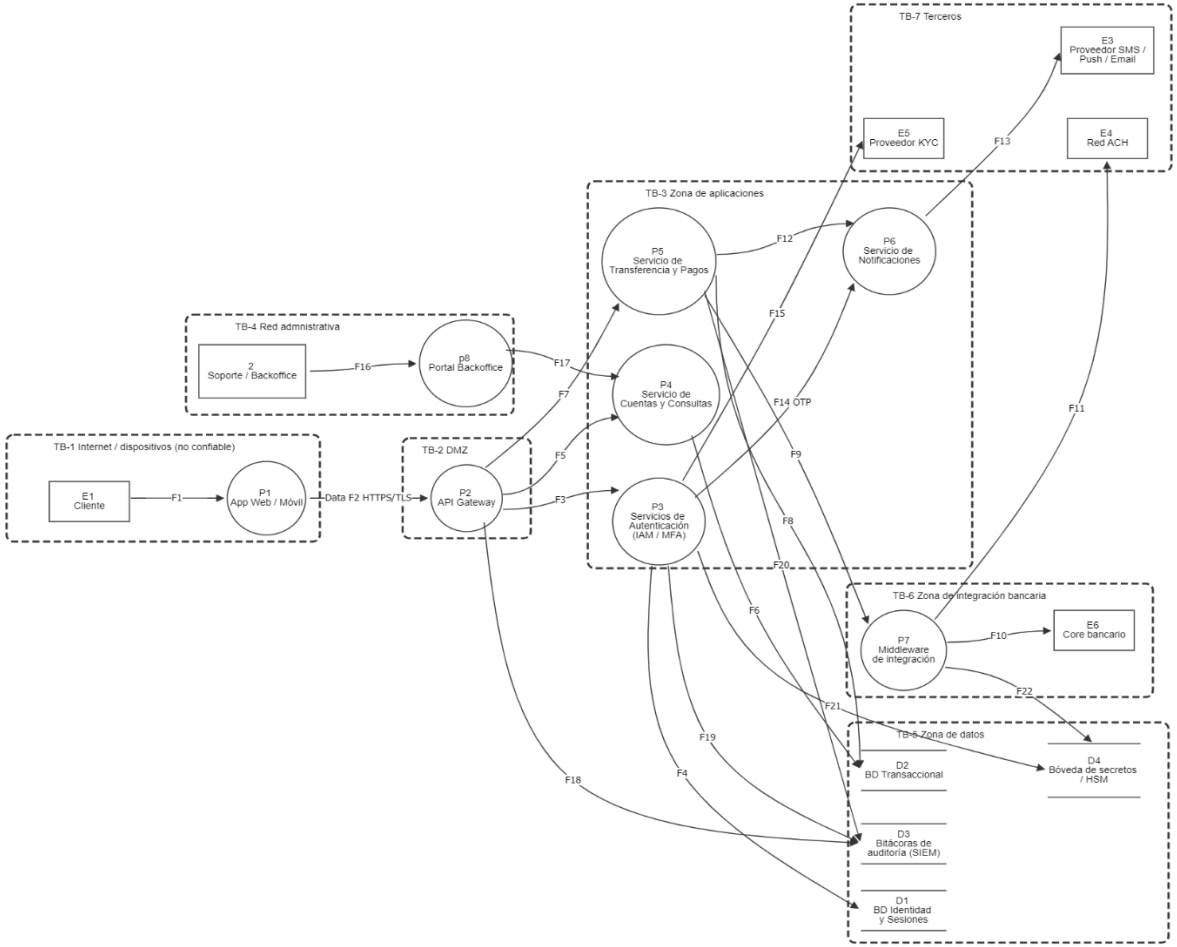


Nota. Elaboración propia.

3.3 DFD Nivel 1 – Procesos principales, almacenes y fronteras

Descompone P0 en ocho procesos (P1–P8), cinco almacenes de datos (D1–D5), seis entidades externas (E1–E6), 22 flujos (F1–F22) y siete fronteras de confianza (TB-1 a TB-7). Los datos de cada flujo se describen en la tabla 2.5.

Figura 2
DFD Nivel 1



Nota. Elaboración propia.

3.4 Fronteras de confianza (Trust Boundaries)

Tabla 5

Fronteras de confianza (Trust Boundaries)

ID	Frontera	Descripción y elementos	Controles esperados al cruzarla
TB-1	Internet / dispositivos del cliente	Zona no confiable: E1 y P1 (código ejecutado en el dispositivo del usuario).	TLS 1.2+/1.3, certificate pinning, protección de la app, validación completa en servidor (nunca confiar en el cliente).
TB-2	DMZ	P2 WAF + API Gateway; punto único de entrada.	WAF, validación de tokens (OIDC), rate limiting, validación de esquemas, anti-DDoS.
TB-3	Zona de aplicaciones	P3, P4, P5 y P6.	mTLS entre servicios, RBAC / ABAC, validación de entradas, secretos desde bóveda.
TB-4	Red administrativa	E2 y P8 (acceso interno de soporte).	VPN / bastión, MFA, PAM, aprobación dual, cuentas nominales.
TB-5	Zona de datos	D1 a D5.	Segmentación estricta, cifrado en reposo, privilegios mínimos, DAM, respaldo inmutable.
TB-6	Zona de integración bancaria	P7 y E6.	mTLS, firma / MAC de mensajes con HSM, listas blancas de origen, monitoreo de conciliación.
TB-7	Terceros	E3, E4 y E5.	Canales cifrados y autenticados, SLA y cláusulas de seguridad, minimización de datos enviados.

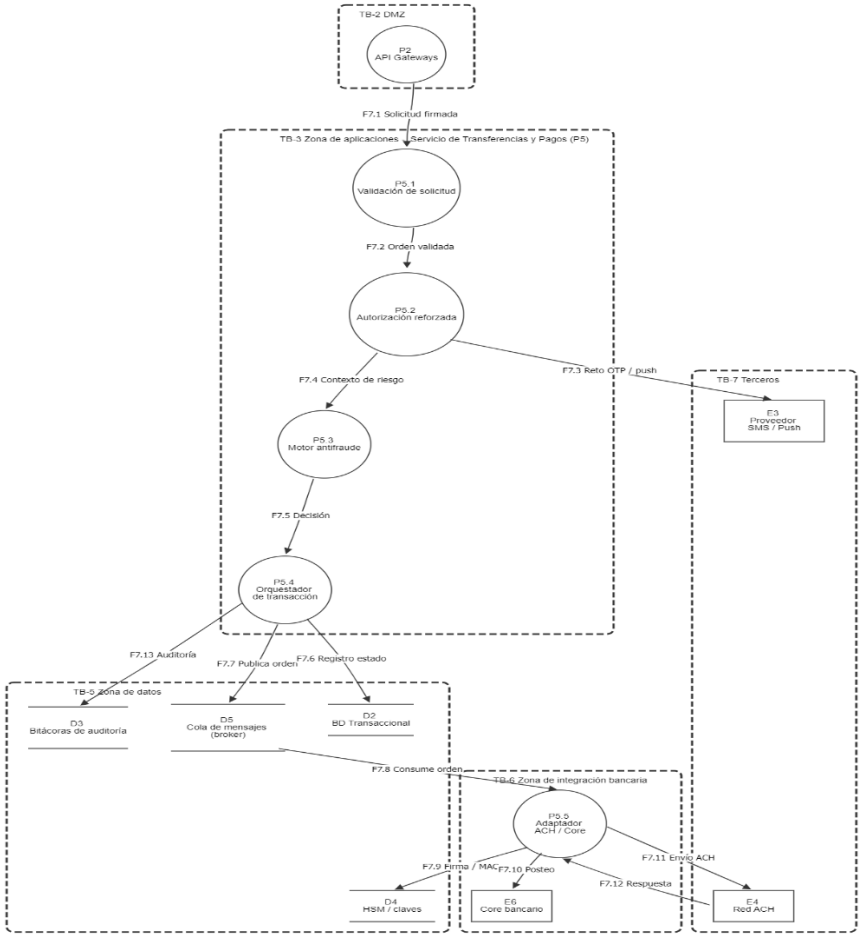
Nota. TB = frontera de confianza. Elaboración propia.

3.5 DFD Nivel 2 – Transferencias, middleware e integración bancaria

Detalla el componente más crítico (P5) y su integración con el Core y la red ACH. Incluye validación de negocio, autorización reforzada, antifraude, orquestación idempotente, cola de mensajes y firma de mensajes con HSM.

Figura 3

DFD Nivel 2 – Transferencias y pagos



Nota. Elaboración propia.

Tabla 6

Elementos del DFD Nivel 2 y amenazas relevantes

ID	Elemento	Descripción	Amenazas relevantes
P5.1	Validación de solicitud	Verifica formato, cuentas, límites y reglas de negocio en servidor.	T03, T13
P5.2	Autorización reforzada	Step-up MFA y firma de la transacción vinculada a monto y destino.	T01, T06
P5.3	Motor antifraude	Evalúa contexto de riesgo (dispositivo, IP, monto, beneficiario).	T30
P5.4	Orquestador de transacción	Aplica idempotencia, registra estado y publica la orden en la cola.	T06, T20
P5.5	Adaptador ACH / Core	Consume la cola, firma con HSM y envía a Core y ACH.	T04, T19, T26

Nota. Los identificadores corresponden a los elementos del DFD Nivel 2 (Figura 3); las amenazas (T) se detallan en la Tabla 9. Elaboración propia.

Tabla 7

Flujos de datos del DFD Nivel 2

ID	Origen → Destino	Datos	Canal	Frontera
F7.1	P2 → P5.1	Solicitud firmada	mTLS	TB-2 → TB-3
F7.2	P5.1 → P5.2	Orden validada	Interno	TB-3
F7.3	P5.2 → E3	Reto OTP / push	HTTPS API	TB-3 → TB-7
F7.4	P5.2 → P5.3	Contexto de riesgo	Interno	TB-3
F7.5	P5.3 → P5.4	Decisión (aprobar / retener / rechazar)	Interno	TB-3
F7.6	P5.4 → D2	Registro de estado	TLS / SQL	TB-3 → TB-5
F7.7	P5.4 → D5	Publicación de la orden	TLS (broker)	TB-3 → TB-5
F7.8	D5 → P5.5	Consumo de la orden	TLS (broker)	TB-5 → TB-6
F7.9	P5.5 → D4	Solicitud de firma / MAC	API HSM	TB-6 → TB-5
F7.10	P5.5 → E6	Posteo en Core	mTLS	TB-6
F7.11	P5.5 → E4	Envío ACH	Canal dedicado + firma	TB-6 → TB-7
F7.12	E4 → P5.5	Respuesta y conciliación	Canal dedicado + firma	TB-7 → TB-6
F7.13		Evento de auditoría	Syslog TLS	TB-3 → TB-5

Nota. F = flujo de datos; mTLS = TLS mutuo; TB = frontera de confianza. Elaboración propia.

3.6 Evidencias de Threat Dragon

Los diagramas presentados en las secciones anteriores fueron elaborados utilizando la versión de escritorio de OWASP Threat Dragon (v2.6.2, instalador de Windows Threat-Dragon-ng-Setup-2.6.2.exe), con fecha 07 de octubre de 2026.

4. Análisis de amenazas mediante STRIDE

4.1 Método

Se aplicó STRIDE por elemento: cada tipo de elemento del DFD es susceptible a un subconjunto de categorías. Se revisó cada flujo, proceso y almacén de datos del Nivel 1 y los elementos críticos del Nivel 2.

Tabla 8

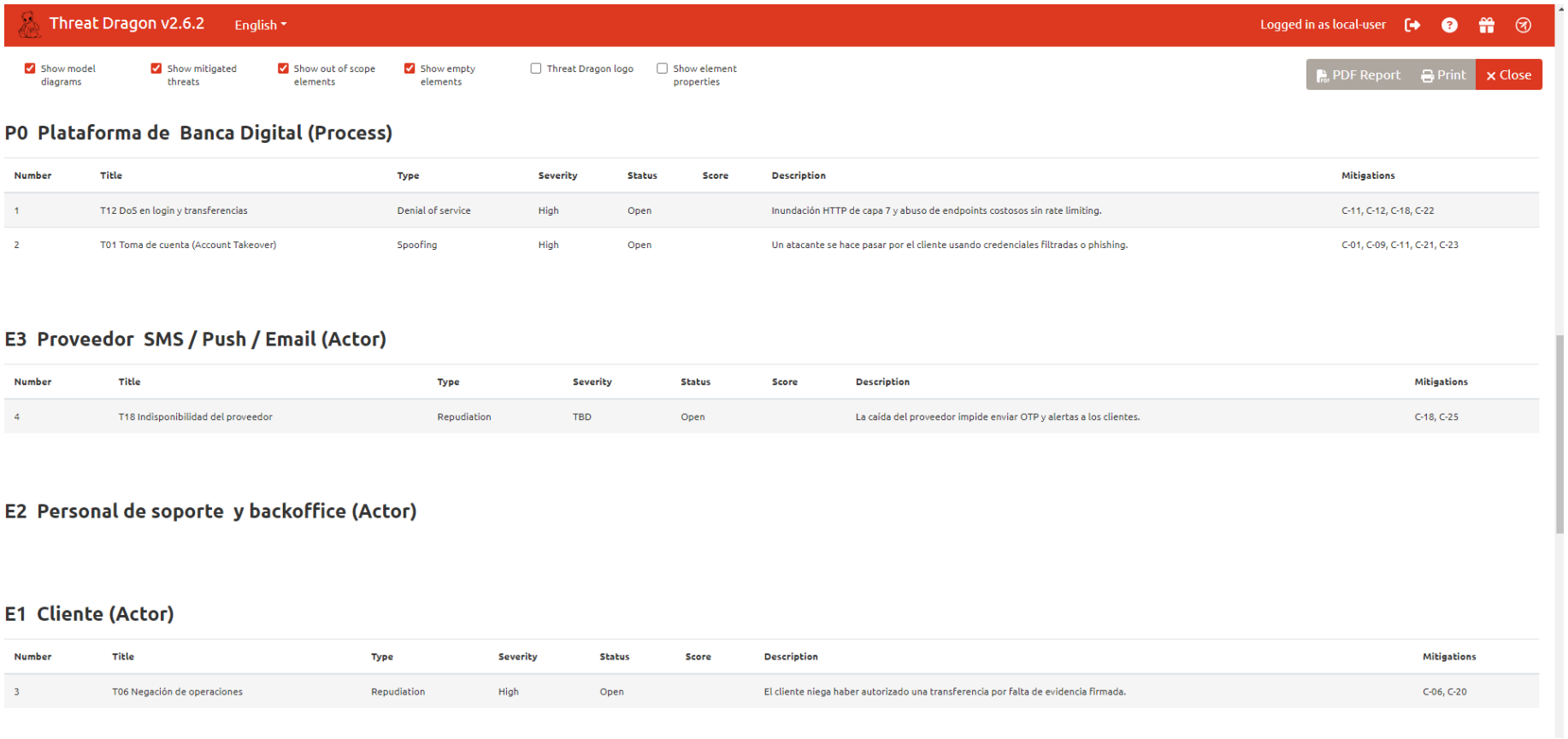
Aplicabilidad de STRIDE por tipo de elemento

Tipo de elemento	S	T	R	I	D	E
Entidad externa	●		●			
Proceso	●	●	●	●	●	●
Almacén de datos		●	●*	●	●	
Flujo de datos		●		●	●	

** Aplica a almacenes de bitácoras / auditoría. Spoofing = suplantación; Tampering = manipulación; Repudiation = repudio; Information Disclosure = divulgación; Denial of Service = denegación de servicio; Elevation of Privilege = elevación de privilegios.*

Nota. Un punto (●) indica que la categoría STRIDE aplica al tipo de elemento. Elaboración propia a partir de la metodología STRIDE por elemento.

Figura 4
Lista de amenazas generada por Threat Dragon (DFD Nivel 0)



Nota. Elaboración propia.

Figura 5
Lista de amenazas generada por Threat Dragon (DFD Nivel 1)

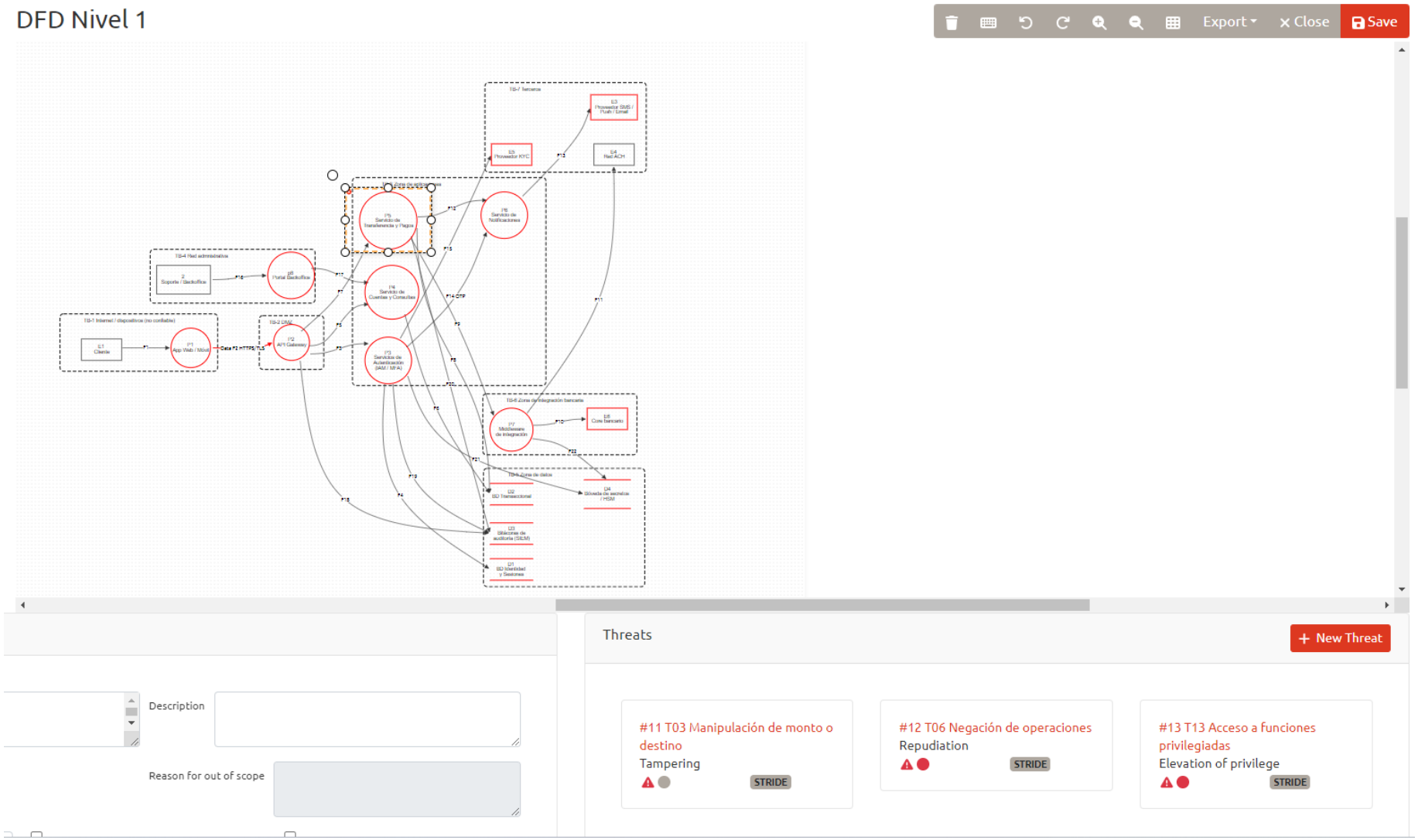
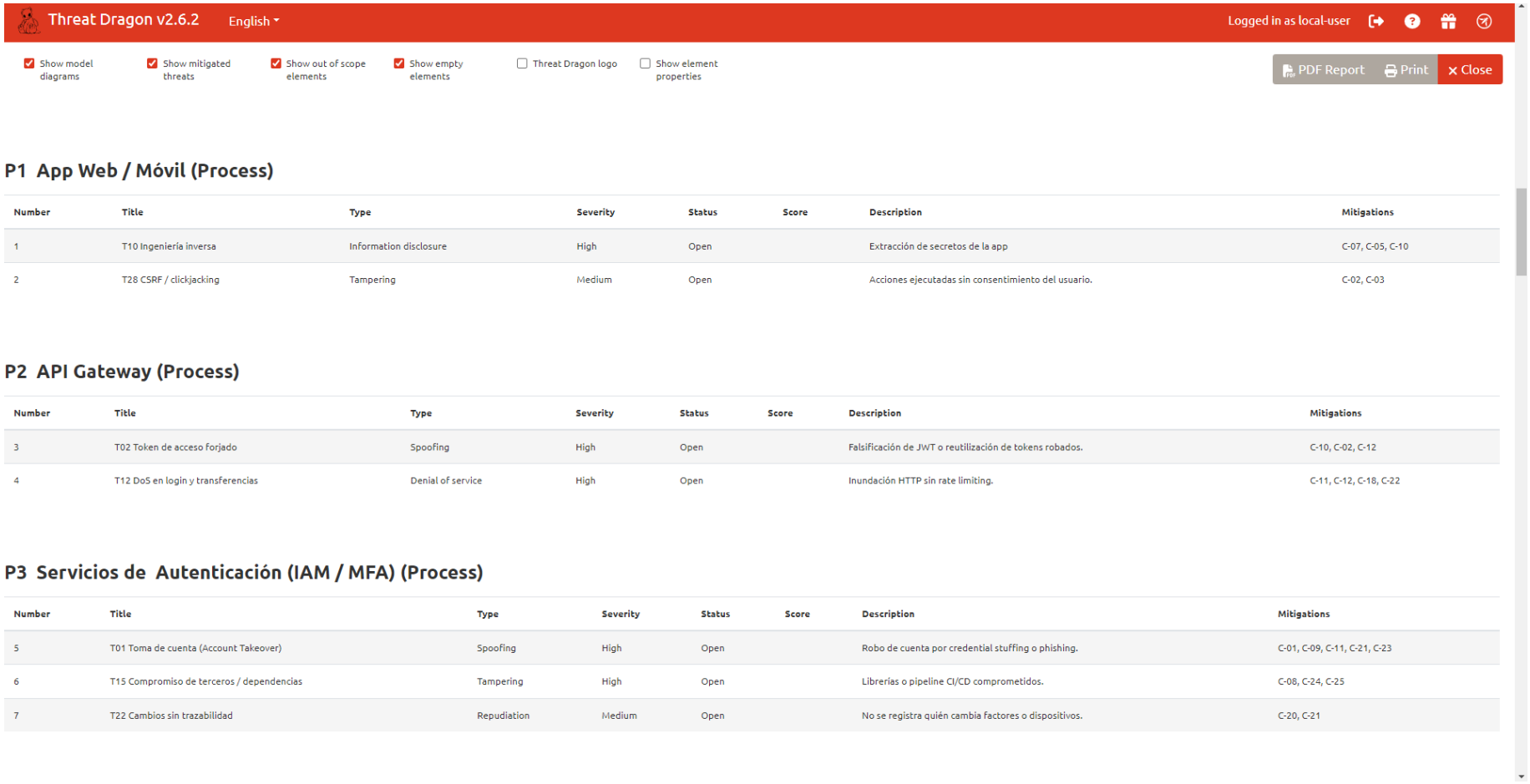


Figura 5



P1 App Web / Móvil (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
1	T10 Ingeniería inversa	Information disclosure	High	Open		Extracción de secretos de la app	C-07, C-05, C-10
2	T28 CSRF / clickjacking	Tampering	Medium	Open		Acciones ejecutadas sin consentimiento del usuario.	C-02, C-03

P2 API Gateway (Process)

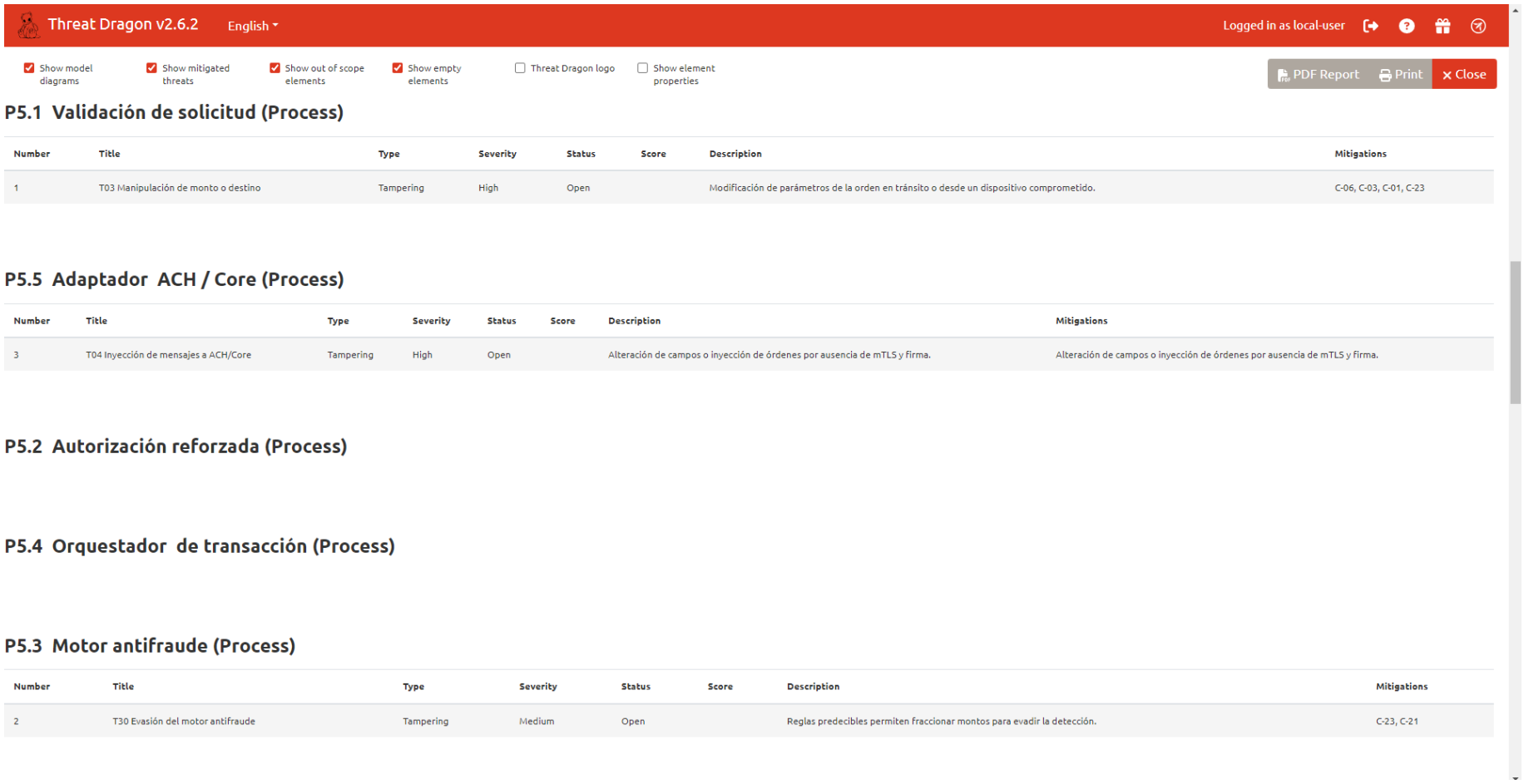
Number	Title	Type	Severity	Status	Score	Description	Mitigations
3	T02 Token de acceso forjado	Spoofing	High	Open		Falsificación de JWT o reutilización de tokens robados.	C-10, C-02, C-12
4	T12 DoS en login y transferencias	Denial of service	High	Open		Inundación HTTP sin rate limiting.	C-11, C-12, C-18, C-22

P3 Servicios de Autenticación (IAM / MFA) (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
5	T01 Toma de cuenta (Account Takeover)	Spoofing	High	Open		Robo de cuenta por credential stuffing o phishing.	C-01, C-09, C-11, C-21, C-23
6	T15 Compromiso de terceros / dependencias	Tampering	High	Open		Librerías o pipeline CI/CD comprometidos.	C-08, C-24, C-25
7	T22 Cambios sin trazabilidad	Repudiation	Medium	Open		No se registra quién cambia factores o dispositivos.	C-20, C-21

Nota. Elaboración propia.

Figura 6
Lista de amenazas generada por Threat Dragon (DFD Nivel 2)



Nota. Elaboración propia.

4.2 Catálogo de amenazas identificadas

Tabla 9

Catálogo de amenazas identificadas

ID	Elemento(s)	STRIDE	Amenaza	Impacto	Prob.	Riesgo	Controles
T01	P3, E1	Spoofing	**Toma de cuenta por credential stuffing, phishing o SIM swap.** Un atacante se hace pasar por el cliente usando credenciales filtradas o reutilizadas, phishing con retransmisión del OTP o intercambio fraudulento de SIM.	Crítico	Alta	**Crítico (12)**	C-01, C-09, C-11, C-21, C-23
T02	P2	Spoofing	**Token de acceso forjado o reutilizado.** Falsificación de JWT (alg=none, secreto débil, claims alterados) o reutilización de tokens robados por validación incompleta en el gateway.	Alto	Media	**Alto (6)**	C-10, C-02, C-12
T03	P5, F7	Tampering	**Manipulación de monto o cuenta destino en la orden de transferencia.** Modificación de parámetros de la orden (monto, beneficiario) en tránsito o desde un dispositivo comprometido, sin firma de la transacción ni revalidación en servidor.	Crítico	Alta	**Crítico (12)**	C-06, C-03, C-01, C-23
T04	P7, F11	Tampering	**Alteración o inyección de mensajes hacia ACH / Core.** Un atacante con acceso a la red de integración altera campos o inyecta órdenes por ausencia de mTLS y de firma / MAC de los mensajes.	Crítico	Media	**Alto (8)**	C-06, C-14, C-16, C-23
T05	D2	Tampering	**Modificación no autorizada de saldos o transacciones en la BD.** Cambios directos por un insider con privilegios excesivos o por SQL injection, sin controles de integridad ni monitoreo de actividad de la base de datos.	Crítico	Media	**Alto (8)**	C-19, C-03, C-17, C-21
T06	P5, E1	Repudiation	**Negación de operaciones por falta de no repudio.** El cliente o un empleado niega haber autorizado una transferencia; no existe evidencia firmada ni vinculación con dispositivo, factor de autenticación y sello de tiempo.	Alto	Alta	**Crítico (9)**	C-06, C-20
T07	D3	Tampering	**Alteración o borrado de bitácoras de auditoría.** Un atacante o insider modifica o elimina registros para ocultar fraude o acciones indebidas.	Medio	Media	**Medio (4)**	C-20, C-19, C-17
T08	P4, D2	Information Disclosure	**Exposición masiva de datos por BOLA / IDOR o SQL injection.** La API de cuentas sin autorización a nivel de objeto, o con consultas dinámicas, permite leer datos de otros clientes y volcar tablas completas.	Crítico	Alta	**Crítico (12)**	C-04, C-03, C-12, C-21
T09	D4	Information Disclosure	**Compromiso de secretos y claves criptográficas.** Secretos en repositorios, variables de entorno o respaldos permiten acceder a Core / ACH y falsificar firmas.	Crítico	Media	**Alto (8)**	C-16, C-24, C-21

ID	Elemento(s)	STRIDE	Amenaza	Impacto	Prob.	Riesgo	Controles
T10	P1	Information Disclosure	**Ingeniería inversa y almacenamiento inseguro en la app móvil.** Extracción de claves, lógica y datos locales; evasión de controles por falta de pinning, ofuscación y detección de root / jailbreak.	Alto	Alta	**Crítico (9)**	C-07, C-05, C-10
T11	F2	Information Disclosure	**Intercepción de tráfico (MITM) por TLS débil.** Versiones o suites TLS obsoletas y ausencia de pinning permiten interceptar tráfico en redes hostiles.	Alto	Baja	**Medio (3)**	C-05, C-07
T12	P2	Denial of Service	**Denegación de servicio en login y transferencias.** Inundación HTTP de capa 7 y abuso de endpoints costosos sin rate limiting ni protección anti-DDoS.	Alto	Media	**Alto (6)**	C-11, C-12, C-18, C-22
T13	P5	Elevation of Privilege	**Acceso a funciones privilegiadas (BFLA).** Un cliente invoca funciones administrativas o de otros roles porque la verificación de rol se hace solo en el front-end.	Crítico	Media	**Alto (8)**	C-04, C-12, C-21
T14	P8, E2	Elevation of Privilege	**Abuso de privilegios en el backoffice.** Cuenta de soporte comprometida o abusada cambia contactos, MFA o límites de clientes sin aprobación dual ni MFA para el personal.	Crítico	Alta	**Crítico (12)**	C-17, C-21, C-20
T15	P1, P3, P5, P7	Tampering	**Compromiso de dependencias de terceros y cadena de suministro.** Librerías, imágenes de contenedor o pipelines CI/CD comprometidos introducen código malicioso (typosquatting, dependency confusion).	Crítico	Media	**Alto (8)**	C-08, C-24, C-25
T16	P4	Information Disclosure	**Datos personales en logs y mensajes de error.** Trazas y errores detallados exponen datos personales, tokens o números de cuenta.	Medio	Media	**Medio (4)**	C-20, C-03
T17	E3	Spoofing	**Suplantación del banco por SMS / correo (smishing).** Atacantes envían mensajes que aparentan ser del banco para capturar credenciales u OTP del cliente.	Medio	Media	**Medio (4)**	C-25, C-22, C-01
T18	E3	Denial of Service	**Indisponibilidad del proveedor de SMS / Push.** La caída del proveedor impide enviar OTP y alertas, bloqueando operaciones de los clientes.	Medio	Media	**Medio (4)**	C-18, C-25
T19	P7	Denial of Service	**Propagación de lentitud o caída del Core / ACH.** Sin timeouts, reintentos controlados ni circuit breakers, un fallo externo satura la plataforma.	Alto	Baja	**Medio (3)**	C-18, C-13
T20	D5	Tampering	**Replay o duplicación de órdenes en la cola.** Reinserción de mensajes o reintentos sin idempotencia producen doble ejecución de una transferencia.	Alto	Baja	**Medio (3)**	C-13, C-06
T21	D1	Information Disclosure	**Exposición de credenciales por hashes débiles.** Si la BD de identidad es filtrada, hashes con algoritmos débiles facilitan el descifrado de contraseñas.	Alto	Baja	**Medio (3)**	C-09, C-19

ID	Elemento(s)	STRIDE	Amenaza	Impacto	Prob.	Riesgo	Controles
T22	P3	Repudiation	**Cambios de dispositivo o credenciales sin trazabilidad.** No se registra quién, cuándo y desde dónde se cambian factores de autenticación o dispositivos de confianza.	Medio	Media	**Medio (4)**	C-20, C-21
T23	P8	Repudiation	**Acciones de soporte sin identidad individual.** El uso de cuentas compartidas impide atribuir cambios realizados en el backoffice.	Medio	Media	**Medio (4)**	C-17, C-20
T24	P4	Elevation of Privilege	**Endpoints de depuración o administración expuestos.** Actuators, consolas o rutas de prueba habilitadas en producción permiten ejecutar acciones privilegiadas.	Alto	Baja	**Medio (3)**	C-15, C-12
T25	E5	Information Disclosure	**Sobreexposición de datos personales hacia el proveedor KYC.** Se envían más datos de los necesarios o sin cláusulas de protección, ampliando la superficie de fuga.	Alto	Baja	**Medio (3)**	C-25, C-05
T26	E6	Spoofing	**Suplantación del endpoint del Core / ACH.** Sin validación estricta de certificados, un atacante interno (p. ej. DNS spoofing) se hace pasar por el Core o por el ACH.	Crítico	Baja	**Medio (4)**	C-05, C-14, C-12
T27	D3	Denial of Service	**Saturación del almacenamiento de bitácoras.** La generación masiva de eventos agota la capacidad y degrada el SIEM.	Bajo	Media	**Bajo (2)**	C-20, C-22
T28	P1	Tampering	**CSRF / clickjacking en la app web.** Acciones no financieras (cambio de preferencias) ejecutadas sin consentimiento del usuario.	Medio	Media	**Medio (4)**	C-02, C-03
T29	P6	Information Disclosure	**Plantillas de notificación con datos sensibles.** Alertas que muestran saldos o datos completos en pantalla bloqueada o por canales inseguros.	Bajo	Media	**Bajo (2)**	C-03, C-22
T30	P5.3	Tampering	**Evasión del motor antifraude por fraccionamiento.** Reglas predecibles permiten fraccionar montos o manipular señales de contexto para evadir la detección.	Medio	Media	**Medio (4)**	C-23, C-21

Nota. T = amenaza; el valor entre paréntesis es el puntaje de riesgo (probabilidad × impacto); C = control (ver Tabla 33). Elaboración propia.

4.3 Matriz STRIDE consolidada

Cada celda lista las amenazas (IDs) que afectan al elemento en esa categoría. «—» indica que se analizó la categoría y no se identificó una amenaza relevante adicional.

Tabla 10
Matriz STRIDE consolidada

Elemento	S	T	R	I	D	E
E1 – Cliente	**T01**	—	**T06**	—	—	—
E2 – Personal de soporte / backoffice	—	—	—	—	—	**T14**
E3 – Proveedor SMS / Push / Email	**T17**	—	—	—	**T18**	—
E4 – Red ACH	—	—	—	—	—	—
E5 – Proveedor KYC / Buró	—	—	—	**T25**	—	—
E6 – Core bancario	**T26**	—	—	—	—	—
P1 – App Web / Móvil	—	**T15, T28**	—	**T10**	—	—
P2 – WAF + API Gateway	**T02**	—	—	—	**T12**	—
P3 – Servicio de Autenticación	**T01**	**T15**	**T22**	—	—	—
P4 – Servicio de Cuentas y Consultas	—	—	—	**T08, T16**	—	**T24**
P5 – Servicio de Transferencias y Pagos	—	**T03, T15**	**T06**	—	—	**T13**
P5.3 – Motor antifraude	—	**T30**	—	—	—	—
P6 – Servicio de Notificaciones	—	—	—	**T29**	—	—
P7 – Middleware de integración	—	**T04, T15**	—	—	**T19**	—
P8 – Portal Backoffice	—	—	**T23**	—	—	**T14**
D1 – BD Identidad y Sesiones	—	—	—	**T21**	—	—
D2 – BD Transaccional	—	**T05**	—	**T08**	—	—
D3 – Bitácoras de auditoría (SIEM)	—	**T07**	—	—	**T27**	—
D4 – Bóveda de secretos / HSM	—	—	—	**T09**	—	—
D5 – Cola de mensajes	—	**T20**	—	—	—	—
F2 – Flujo F2 (App → Gateway)	—	—	—	**T11**	—	—

Elemento	S	T	R	I	D	E
F7 – Flujo F7 (Orden de transferencia)	—	**T03**	—	—	—	—
F11 – Flujo F11 (Middleware ↔ ACH)	—	**T04**	—	—	—	—

Color de la celda = nivel de la amenaza más severa de la celda (rojo = Crítico, naranja = Alto, amarillo = Medio, verde = Bajo).

Nota. Cada celda lista los identificadores de amenaza (T) de la Tabla 9; el guion (—) indica que no se identificó una amenaza para esa combinación. Elaboración propia.

4.4 Registro de validación técnica

Las amenazas deben validarse con Arquitectura y Desarrollo. Completa este registro con la información real de la sesión de validación.

Tabla 11

Registro de validación técnica

Fecha de la sesión de validación	06/10/2026
Modalidad	Virtual (Microsoft Teams)
Participante de Arquitectura (nombre y cargo)	Ing. Carlos Mendoza – Arquitecto de Soluciones
Participante de Desarrollo (nombre y cargo)	Ing. Lucía Estrada – Líder de Desarrollo Backend
Elementos y amenazas revisados	DFD Nivel 0, Nivel 1 y Nivel 2; Catálogo completo de amenazas (T01–T30).
Ajustes solicitados al DFD	Se confirmó la topología presentada; no se requirieron cambios en las fronteras de confianza (Trust Boundaries).
Amenazas añadidas, modificadas o descartadas	Se validó el catálogo sin descartar ninguna. Se confirmó la alta prioridad de mitigación para T01 y T03.
Resultado de la validación	Aprobado
Versión del modelo resultante	v1.1

Nota. Registro elaborado a partir de la sesión de validación con los responsables de Arquitectura y Desarrollo.

5. Priorización de riesgos

5.1 Criterios y escala

Se aplica la fórmula vista en clase, **Riesgo = Probabilidad × Impacto**, con escalas de 1 a 4. El nivel resultante es coherente con la tabla del enunciado: Alto × Alto = Crítico (9), Alto × Medio = Alto (6), Medio × Medio = Medio (4) y Bajo × Bajo = Bajo (1).

Tabla 12

Escala de impacto

Impacto	Valor	Criterio
Crítico	4	Pérdida financiera severa o fraude masivo; fuga masiva de datos de clientes; incumplimiento regulatorio mayor; indisponibilidad superior a 24 h.
Alto	3	Pérdida financiera significativa; fuga limitada de datos; observación o sanción regulatoria; indisponibilidad de 4 a 24 h.
Medio	2	Impacto acotado a pocos clientes o procesos; indisponibilidad de 1 a 4 h; recuperación con esfuerzo moderado.
Bajo	1	Impacto mínimo; sin pérdida financiera ni exposición de datos sensibles.

Nota. Los valores de 1 a 4 se utilizan para calcular el riesgo (P × I). Elaboración propia.

Tabla 13

Escala de probabilidad

Probabilidad	Valor	Criterio
Muy Alta	4	Explotación trivial o ya observada en el sector; se espera en menos de 3 meses.
Alta	3	Técnicas conocidas con herramientas públicas; probable en los próximos 12 meses.
Media	2	Requiere condiciones o habilidades específicas; posible en 12–24 meses.
Baja	1	Requiere acceso privilegiado o múltiples fallas simultáneas; improbable.

Nota. Los valores de 1 a 4 se utilizan para calcular el riesgo (P × I). Elaboración propia.

Tabla 14

Niveles de riesgo y decisión de tratamiento

Nivel	Puntaje (P × I)	Decisión de tratamiento (Semana 2)
Crítico	9 – 16	Mitigar de inmediato (0–3 meses). Transferir solo de forma parcial; la responsabilidad permanece en la organización.
Alto	6 – 8	Mitigar con plan formal (0–6 meses).

Nivel	Puntaje (P × I)	Decisión de tratamiento (Semana 2)
Medio	3 – 5	Mitigar planificadamente (3–12 meses) o transferir (contratos / SLA).
Bajo	1 – 2	Aceptar con monitoreo; documentar la aceptación por el dueño del riesgo.

Nota. P × I = probabilidad × impacto. Elaboración propia.

Opciones de tratamiento: mitigar, aceptar, transferir y evitar. El tratamiento reduce el riesgo hasta un nivel compatible con el apetito y la tolerancia de la organización; transferir no elimina la responsabilidad.

5.2 Matriz de riesgos (impacto × probabilidad)

Tabla 15

Matriz de riesgos (impacto × probabilidad)

Impacto \ Probabilidad	Baja (1)	Media (2)	Alta (3)	Muy Alta (4)
Crítico (4)	(4) T26	(8) T04, T05, T09, T13, T15	(12) T01, T03, T08, T14	(16)
Alto (3)	(3) T11, T19, T20, T21, T24, T25	(6) T02, T12	(9) T06, T10	(12)
Medio (2)	(2)	(4) T07, T16, T17, T18, T22, T23, T28, T30	(6)	(8)
Bajo (1)	(1)	(2) T27, T29	(3)	(4)

Entre paréntesis, el puntaje P × I de cada celda. Ninguna amenaza se ubicó en probabilidad «Muy Alta» tras considerar los controles perimetrales existentes (supuesto a validar).

Nota. Elaboración propia a partir del catálogo de amenazas (Tabla 9).

5.3 Ranking de amenazas

Tabla 16

Ranking de amenazas

#	ID	Amenaza	STRIDE	Impacto	Prob.	P×I	Nivel	Tratamiento
1	T01	Toma de cuenta por credential stuffing, phishing o SIM swap	Spoofing	Crítico	Alta	**12**	**Crítico**	Mitigar
2	T03	Manipulación de monto o cuenta destino en la orden de transferencia	Tampering	Crítico	Alta	**12**	**Crítico**	Mitigar
3	T08	Exposición masiva de datos por BOLA / IDOR o SQL injection	Information Disclosure	Crítico	Alta	**12**	**Crítico**	Mitigar
4	T14	Abuso de privilegios en el backoffice	Elevation of Privilege	Crítico	Alta	**12**	**Crítico**	Mitigar
5	T06	Negación de operaciones por falta de no repudio	Repudiation	Alto	Alta	**9**	**Crítico**	Mitigar
6	T10	Ingeniería inversa y almacenamiento inseguro en la app móvil	Information Disclosure	Alto	Alta	**9**	**Crítico**	Mitigar
7	T04	Alteración o inyección de mensajes hacia ACH / Core	Tampering	Crítico	Media	**8**	**Alto**	Mitigar
8	T05	Modificación no autorizada de saldos o transacciones en la BD	Tampering	Crítico	Media	**8**	**Alto**	Mitigar
9	T09	Compromiso de secretos y claves criptográficas	Information Disclosure	Crítico	Media	**8**	**Alto**	Mitigar
10	T13	Acceso a funciones privilegiadas (BFLA)	Elevation of Privilege	Crítico	Media	**8**	**Alto**	Mitigar
11	T15	Compromiso de dependencias de terceros y cadena de suministro	Tampering	Crítico	Media	**8**	**Alto**	Mitigar / Transferir (contratos)
12	T02	Token de acceso forjado o reutilizado	Spoofing	Alto	Media	**6**	**Alto**	Mitigar
13	T12	Denegación de servicio en login y transferencias	Denial of Service	Alto	Media	**6**	**Alto**	Mitigar
14	T26	Suplantación del endpoint del Core / ACH	Spoofing	Crítico	Baja	**4**	**Medio**	Mitigar
15	T07	Alteración o borrado de bitácoras de auditoría	Tampering	Medio	Media	**4**	**Medio**	Mitigar
16	T16	Datos personales en logs y mensajes de error	Information Disclosure	Medio	Media	**4**	**Medio**	Mitigar
17	T17	Suplantación del banco por SMS / correo (smishing)	Spoofing	Medio	Media	**4**	**Medio**	Mitigar
18	T18	Indisponibilidad del proveedor de SMS / Push	Denial of Service	Medio	Media	**4**	**Medio**	Mitigar / Transferir (SLA)

#	ID	Amenaza	STRIDE	Impacto	Prob.	P×I	Nivel	Tratamiento
19	T22	Cambios de dispositivo o credenciales sin trazabilidad	Repudiation	Medio	Media	**4**	**Medio**	Mitigar
20	T23	Acciones de soporte sin identidad individual	Repudiation	Medio	Media	**4**	**Medio**	Mitigar
21	T28	CSRF / clickjacking en la app web	Tampering	Medio	Media	**4**	**Medio**	Mitigar
22	T30	Evasión del motor antifraude por fraccionamiento	Tampering	Medio	Media	**4**	**Medio**	Mitigar
23	T11	Intercepción de tráfico (MITM) por TLS débil	Information Disclosure	Alto	Baja	**3**	**Medio**	Mitigar
24	T19	Propagación de lentitud o caída del Core / ACH	Denial of Service	Alto	Baja	**3**	**Medio**	Mitigar
25	T20	Replay o duplicación de órdenes en la cola	Tampering	Alto	Baja	**3**	**Medio**	Mitigar
26	T21	Exposición de credenciales por hashes débiles	Information Disclosure	Alto	Baja	**3**	**Medio**	Mitigar
27	T24	Endpoints de depuración o administración expuestos	Elevation of Privilege	Alto	Baja	**3**	**Medio**	Mitigar
28	T25	Sobreexposición de datos personales hacia el proveedor KYC	Information Disclosure	Alto	Baja	**3**	**Medio**	Mitigar / Transferir (DPA)
29	T27	Saturación del almacenamiento de bitácoras	Denial of Service	Bajo	Media	**2**	**Bajo**	Aceptar (monitorear)
30	T29	Plantillas de notificación con datos sensibles	Information Disclosure	Bajo	Media	**2**	**Bajo**	Aceptar (monitorear)

Nota. P × I = probabilidad × impacto; las amenazas se ordenan según su puntaje de riesgo. Elaboración propia.

5.4 Top 10 de hallazgos prioritarios

Tabla 17

Top 10 de hallazgos prioritarios

#	ID	Hallazgo	Elemento(s)	Nivel	Acción prioritaria
1	T01	Toma de cuenta por credential stuffing, phishing o SIM swap	P3, E1	**Crítico**	Implementar MFA resistente a phishing, anti-bot y verificación de contraseñas filtradas.
2	T03	Manipulación de monto o cuenta destino en la orden de transferencia	P5, F7	**Crítico**	Firma de transacción (WYSIWYS) y revalidación server-side de la orden.
3	T08	Exposición masiva de datos por BOLA / IDOR o SQL injection	P4, D2	**Crítico**	Autorización por objeto en todos los endpoints, consultas parametrizadas y pruebas DAST.
4	T14	Abuso de privilegios en el backoffice	P8, E2	**Crítico**	PAM, MFA y aprobación dual para cambios sensibles en backoffice.
5	T06	Negación de operaciones por falta de no repudio	P5, E1	**Crítico**	Evidencia de autorización firmada y con sello de tiempo por operación.
6	T10	Ingeniería inversa y almacenamiento inseguro en la app móvil	P1	**Crítico**	Hardening de la app: pinning, attestation, ofuscación y eliminación de secretos.
7	T04	Alteración o inyección de mensajes hacia ACH / Core	P7, F11	**Alto**	mTLS y firma / MAC con HSM en integraciones Core y ACH.
8	T05	Modificación no autorizada de saldos o transacciones en la BD	D2	**Alto**	Privilegios mínimos, DAM y conciliación contable automática.
9	T09	Compromiso de secretos y claves criptográficas	D4	**Alto**	Migrar secretos a bóveda / HSM, escaneo de secretos en CI y rotación.
10	T13	Acceso a funciones privilegiadas (BFLA)	P5	**Alto**	RBAC en servidor, deny by default y lista blanca de rutas.

Nota. Selección de las amenazas de mayor prioridad del ranking (Tabla 16). Elaboración propia.

5.5 Distribución de riesgos

Tabla 18

Distribución de riesgos por nivel

Nivel	Cantidad	Amenazas
Crítico	**6**	T01, T03, T06, T08, T10, T14
Alto	**7**	T02, T04, T05, T09, T12, T13, T15
Medio	**15**	T07, T11, T16, T17, T18, T19, T20, T21, T22, T23, T24, T25, T26, T28, T30

Nivel	Cantidad	Amenazas
Bajo	**2**	T27, T29

Nota. Suman las 30 amenazas modeladas. Elaboración propia.

6. Casos de abuso (Abuse Cases)

Se documentan casos de abuso para las 13 amenazas críticas y altas. Cada caso incluye objetivo del atacante, vector, precondiciones, método de explotación, impacto, controles preventivo, detectivo y correctivo, y el riesgo residual esperado.

6.1 Catálogo resumen

Tabla 19

Catálogo resumen de casos de abuso

Caso	Actor	Objetivo	STRIDE	Riesgo	Mitigación principal
CA-01 (T01)	Atacante externo (ciberdelincuente)	Acceso no autorizado a cuentas de clientes para transferir fondos.	Spoofing	**Crítico**	MFA resistente a phishing y step-up; Almacenamiento seguro de credenciales; Rate limiting y protección anti-bot / DDoS
CA-02 (T02)	Usuario malicioso / atacante externo	Suplantar a otro usuario o elevar su acceso con un token forjado.	Spoofing	**Alto**	OAuth 2.0 / OIDC; Gestión segura de sesiones; Seguridad en API Gateway
CA-03 (T03)	Atacante externo con malware o MITM sobre la app	Manipulación de transacciones (monto o cuenta destino).	Tampering	**Crítico**	Firma e integridad de transacciones; Validación de entradas y minimización de datos; MFA resistente a phishing y step-up
CA-04 (T04)	Insider malicioso / atacante con acceso a red interna	Alterar o inyectar mensajes hacia ACH / Core para desviar fondos.	Tampering	**Alto**	Firma e integridad de transacciones; Segmentación de red; Gestión de secretos y llaves
CA-05 (T05)	Insider (DBA / desarrollador) o atacante con SQL injection	Modificar saldos o historial de transacciones.	Tampering	**Alto**	Protección de bases de datos; Validación de entradas y minimización de datos; Acceso privilegiado y segregación de funciones
CA-06 (T06)	Cliente deshonesto o empleado	Negar una transferencia legítimamente realizada (reclamo fraudulento).	Repudiation	**Crítico**	Firma e integridad de transacciones; Logging centralizado con integridad
CA-07 (T08)	Usuario malicioso autenticado	Acceder a datos de otros clientes (cuentas y saldos).	Information Disclosure	**Crítico**	Autorización a nivel de objeto y de función; Validación de entradas y minimización de datos; Seguridad en API Gateway
CA-08 (T09)	Atacante externo / insider	Obtener secretos y llaves para acceder a Core o ACH.	Information Disclosure	**Alto**	Gestión de secretos y llaves; Pruebas de seguridad continuas; SIEM y casos de uso de detección
CA-09 (T10)	Atacante externo / investigador malicioso	Extraer secretos y lógica, clonar la app o evadir controles.	Information Disclosure	**Crítico**	Protección de la app móvil; Cifrado en tránsito y en reposo; OAuth 2.0 / OIDC
CA-10 (T12)	Hacktivista / extorsionador	Denegar el servicio de banca digital.	Denial of Service	**Alto**	Rate limiting y protección anti-bot / DDoS; Seguridad en API Gateway; Resiliencia y continuidad

Caso	Actor	Objetivo	STRIDE	Riesgo	Mitigación principal
CA-11 (T13)	Usuario malicioso autenticado	Ejecutar funciones privilegiadas (p. ej. aumentar límites).	Elevation of Privilege	**Alto**	Autorización a nivel de objeto y de función; Seguridad en API Gateway; SIEM y casos de uso de detección
CA-12 (T14)	Insider malicioso / atacante con cuenta de soporte comprometida	Cambiar contactos o dispositivos del cliente para sobrepasar el MFA y mover fondos.	Elevation of Privilege	**Crítico**	Acceso privilegiado y segregación de funciones; SIEM y casos de uso de detección; Logging centralizado con integridad
CA-13 (T15)	Atacante de cadena de suministro	Ejecutar código malicioso en la plataforma mediante una dependencia o el pipeline.	Tampering	**Alto**	Seguridad de la cadena de suministro; Pruebas de seguridad continuas; Gestión de seguridad de proveedores

Nota. CA = caso de abuso; entre paréntesis se indica la amenaza (T) vinculada. El detalle de cada caso se presenta en la sección 6.2.

6.2 Detalle de los casos de abuso

CA-01 · Toma de cuenta por credential stuffing, phishing o SIM swap

Tabla 20

Detalle del caso de abuso CA-01 – Toma de cuenta por credential stuffing, phishing o SIM swap

Amenaza vinculada	T01 – Spoofing (elemento(s): P3, E1)
Riesgo inherente	**Crítico (P×I = 12)**
Actor	Atacante externo (ciberdelincuente)
Objetivo del atacante	Acceso no autorizado a cuentas de clientes para transferir fondos.
Vector de ataque	Endpoint de login (P2 → P3) y canal SMS del proveedor (E3).
Precondiciones	Credenciales filtradas de otros sitios y reutilizadas; OTP por SMS como único segundo factor; sin detección de dispositivo nuevo.
Método de explotación	Credential stuffing automatizado con proxies rotativos; página de phishing con retransmisión en tiempo real del OTP (AiTM); SIM swap mediante ingeniería social.
Impacto esperado	Robo de fondos, fraude a clientes, daño reputacional y sanciones regulatorias.
Control preventivo	MFA resistente a phishing (C-01), rate limiting y anti-bot (C-11), verificación de contraseñas filtradas (C-09).
Control detectivo	SIEM: picos de fallos de login, dispositivo o geolocalización nuevos (C-21); analítica de fraude (C-23).
Acción correctiva	Bloqueo de cuenta, restablecimiento forzado de credenciales y sesiones, notificación al cliente, reverso de operaciones fraudulentas.
Riesgo residual estimado	**Medio**

Nota. P × I = probabilidad × impacto; C = control (ver Tabla 33). Elaboración propia.

CA-02 · Token de acceso forjado o reutilizado

Tabla 21

Detalle del caso de abuso CA-02 – Token de acceso forjado o reutilizado

Amenaza vinculada	T02 – Spoofing (elemento(s): P2)
Riesgo inherente	**Alto (P×I = 6)**
Actor	Usuario malicioso / atacante externo
Objetivo del atacante	Suplantar a otro usuario o elevar su acceso con un token forjado.
Vector de ataque	Cabecera Authorization en F2 / F3.
Precondiciones	Gateway que no valida firma, algoritmo ni audiencia; secreto HS256 débil; tokens de larga vida.
Método de explotación	Modificar claims (sub, role), alg=none o confusión RS/HS; reutilizar un token robado desde logs o XSS.
Impacto esperado	Acceso a cuentas y funciones ajenas.
Control preventivo	OAuth 2.0 / OIDC con validación estricta de JWT (C-10), sesiones cortas (C-02), validación en gateway (C-12).
Control detectivo	Alertas por tokens inválidos y reutilización desde IP o dispositivo distintos (C-21).
Acción correctiva	Revocar y rotar llaves de firma (C-16), invalidar sesiones activas, revisar accesos del periodo.

Riesgo residual estimado	**Bajo**

Nota. P × I = probabilidad × impacto; C = control (ver Tabla 33). Elaboración propia.

CA-03 · Manipulación de monto o cuenta destino en la orden de transferencia

Tabla 22

Detalle del caso de abuso CA-03 – Manipulación de monto o cuenta destino en la orden de transferencia

Amenaza vinculada	T03 – Tampering (elemento(s): P5, F7)
Riesgo inherente	**Crítico (P×I = 12)**
Actor	Atacante externo con malware o MITM sobre la app
Objetivo del atacante	Manipulación de transacciones (monto o cuenta destino).
Vector de ataque	Solicitud de transferencia F2 / F7 hacia P5.
Precondiciones	El cliente no firma la orden; el servidor confía en los parámetros recibidos; malware (overlay / web-inject) en el dispositivo.
Método de explotación	Interceptar y modificar el JSON de la orden; reproducir órdenes; cambiar el beneficiario después de la confirmación del OTP.
Impacto esperado	Pérdida financiera directa y reclamaciones de clientes.
Control preventivo	Firma de transacción vinculada a monto y destino (C-06), validaciones de negocio y límites (C-03), confirmación «lo que ves es lo que firmas» (C-01).
Control detectivo	Motor antifraude (C-23) y conciliación de órdenes contra lo autorizado por el cliente.
Acción correctiva	Reverso o recall del movimiento, bloqueo preventivo de cuentas, reporte a las autoridades cuando aplique.
Riesgo residual estimado	**Medio**

Nota. P × I = probabilidad × impacto; C = control (ver Tabla 33). Elaboración propia.

CA-04 · Alteración o inyección de mensajes hacia ACH / Core

Tabla 23

Detalle del caso de abuso CA-04 – Alteración o inyección de mensajes hacia ACH / Core

Amenaza vinculada	T04 – Tampering (elemento(s): P7, F11)
Riesgo inherente	**Alto (P×I = 8)**
Actor	Insider malicioso / atacante con acceso a red interna
Objetivo del atacante	Alterar o inyectar mensajes hacia ACH / Core para desviar fondos.
Vector de ataque	Flujos F9, F10 y F11 (fronteras TB-6 y TB-7).
Precondiciones	Canal sin mTLS ni firma de mensaje; segmentación insuficiente entre zonas.
Método de explotación	Man-in-the-middle en el segmento interno, modificación de la cuenta destino o inyección de órdenes completas.
Impacto esperado	Fraude de gran monto e incumplimiento regulatorio.
Control preventivo	mTLS y firma / MAC con HSM (C-06, C-16); segmentación de red (C-14).
Control detectivo	Conciliación automática y alertas por discrepancias (C-23, C-21).
Acción correctiva	Suspensión del lote, recall interbancario, análisis forense y rotación de llaves.

Riesgo residual estimado	**Bajo**

Nota. P × I = probabilidad × impacto; C = control (ver Tabla 33). Elaboración propia.

CA-05 · Modificación no autorizada de saldos o transacciones en la BD

Tabla 24

Detalle del caso de abuso CA-05 – Modificación no autorizada de saldos o transacciones en la BD

Amenaza vinculada	T05 – Tampering (elemento(s): D2)
Riesgo inherente	**Alto (P×I = 8)**
Actor	Insider (DBA / desarrollador) o atacante con SQL injection
Objetivo del atacante	Modificar saldos o historial de transacciones.
Vector de ataque	Acceso directo a D2 o inyección vía P4 / P5.
Precondiciones	Cuentas de DBA compartidas, sin monitoreo de actividad, consultas dinámicas.
Método de explotación	UPDATE directo sobre tablas de saldos; SQL injection con consultas apiladas.
Impacto esperado	Pérdida de integridad contable y de confianza en los registros.
Control preventivo	Privilegios mínimos y separación de roles en BD (C-19), consultas parametrizadas (C-03), acceso privilegiado controlado (C-17).
Control detectivo	DAM y conciliación contable periódica (C-19, C-21).
Acción correctiva	Restauración desde respaldo / journal, investigación forense y ajuste contable.
Riesgo residual estimado	**Bajo**

Nota. P × I = probabilidad × impacto; C = control (ver Tabla 33). Elaboración propia.

CA-06 · Negación de operaciones por falta de no repudio

Tabla 25

Detalle del caso de abuso CA-06 – Negación de operaciones por falta de no repudio

Amenaza vinculada	T06 – Repudiation (elemento(s): P5, E1)
Riesgo inherente	**Crítico (P×I = 9)**
Actor	Cliente deshonesto o empleado
Objetivo del atacante	Negar una transferencia legítimamente realizada (reclamo fraudulento).
Vector de ataque	Proceso P5 y proceso de reclamaciones.
Precondiciones	La bitácora no vincula la transacción con dispositivo, IP y factor usado; no existe firma de la orden.
Método de explotación	Afirmar que no autorizó la operación, aprovechando la falta de evidencia.
Impacto esperado	Pérdidas por reembolsos y disputas legales.
Control preventivo	Firma y sello de tiempo de la orden (C-06), registro de evidencia de autenticación.
Control detectivo	Revisión de auditoría y correlación de eventos (C-20).
Acción correctiva	Proceso de disputa con evidencia forense e inmutable.
Riesgo residual estimado	**Bajo**

Nota. P × I = probabilidad × impacto; C = control (ver Tabla 33). Elaboración propia.

CA-07 · Exposición masiva de datos por BOLA / IDOR o SQL injection

Tabla 26

Detalle del caso de abuso CA-07 – Exposición masiva de datos por BOLA / IDOR o SQL injection

Amenaza vinculada	T08 – Information Disclosure (elemento(s): P4, D2)
Riesgo inherente	**Crítico (P×I = 12)**
Actor	Usuario malicioso autenticado
Objetivo del atacante	Acceder a datos de otros clientes (cuentas y saldos).
Vector de ataque	API de consulta de cuentas (F5 / F6).
Precondiciones	La autorización solo verifica autenticación (BOLA); identificadores predecibles; consultas dinámicas.
Método de explotación	Enumerar identificadores de cuenta; SQL injection para volcar tablas.
Impacto esperado	Fuga masiva de datos personales y financieros, sanción regulatoria.
Control preventivo	Autorización a nivel de objeto (C-04), consultas parametrizadas (C-03), validación de esquemas y minimización de campos (C-12).
Control detectivo	SIEM: patrones de enumeración y anomalías de volumen (C-21).
Acción correctiva	Contención del endpoint, notificación a afectados y autoridades, revisión de logs y rotación de identificadores.
Riesgo residual estimado	**Medio**

Nota. P × I = probabilidad × impacto; C = control (ver Tabla 33). Elaboración propia.

CA-08 · Compromiso de secretos y claves criptográficas

Tabla 27

Detalle del caso de abuso CA-08 – Compromiso de secretos y claves criptográficas

Amenaza vinculada	T09 – Information Disclosure (elemento(s): D4)
Riesgo inherente	**Alto (P×I = 8)**
Actor	Atacante externo / insider
Objetivo del atacante	Obtener secretos y llaves para acceder a Core o ACH.
Vector de ataque	Repositorios Git, variables de entorno, respaldos.
Precondiciones	Secretos en código o en variables en claro; sin rotación periódica.
Método de explotación	Escaneo de secretos en repositorios y forks; lectura de variables en un contenedor comprometido.
Impacto esperado	Acceso a sistemas críticos y pérdida de confianza en firmas.
Control preventivo	Bóveda / HSM y rotación (C-16), escaneo de secretos en CI (C-24).
Control detectivo	Alertas por uso anómalo de llaves (C-21).
Acción correctiva	Rotación y revocación inmediata, revisión de accesos y de transacciones firmadas.
Riesgo residual estimado	**Bajo**

Nota. P × I = probabilidad × impacto; C = control (ver Tabla 33). Elaboración propia.

CA-09 · Ingeniería inversa y almacenamiento inseguro en la app móvil

Tabla 28

Detalle del caso de abuso CA-09 – Ingeniería inversa y almacenamiento inseguro en la app móvil

Amenaza vinculada	T10 – Information Disclosure (elemento(s): P1)
Riesgo inherente	**Crítico (P×I = 9)**
Actor	Atacante externo / investigador malicioso
Objetivo del atacante	Extraer secretos y lógica, clonar la app o evadir controles.
Vector de ataque	Paquetes APK / IPA distribuidos.
Precondiciones	Claves o API keys embebidas; sin pinning; sin detección de root / jailbreak.
Método de explotación	Ingeniería inversa (jadx, Frida), proxy MITM, reempaquetado de la app.
Impacto esperado	Abuso masivo de APIs, fraude a escala y aplicaciones falsas.
Control preventivo	Protección de la app móvil (C-07), certificate pinning (C-05), PKCE y ausencia de secretos en el cliente (C-10).
Control detectivo	Fallos de attestation y monitoreo de tiendas por apps falsas (C-21).
Acción correctiva	Revocar claves expuestas, forzar actualización, solicitar retiro de apps falsas.
Riesgo residual estimado	**Medio**

Nota. P × I = probabilidad × impacto; C = control (ver Tabla 33). Elaboración propia.

CA-10 · Denegación de servicio en login y transferencias

Tabla 29

Detalle del caso de abuso CA-10 – Denegación de servicio en login y transferencias

Amenaza vinculada	T12 – Denial of Service (elemento(s): P2)
Riesgo inherente	**Alto (P×I = 6)**
Actor	Hacktivista / extorsionador
Objetivo del atacante	Denegar el servicio de banca digital.
Vector de ataque	Endpoints de login y transferencias (capa 7).
Precondiciones	Sin rate limiting ni autoscaling; sin protección DDoS en el perímetro.
Método de explotación	Flood HTTP, slowloris y abuso de endpoints costosos.
Impacto esperado	Indisponibilidad, pérdida de clientes e incumplimiento de niveles de servicio.
Control preventivo	Rate limiting y anti-DDoS (C-11), seguridad del API Gateway (C-12), resiliencia (C-18).
Control detectivo	Umbrales en SIEM / APM y alertamiento (C-22).
Acción correctiva	Activar mitigación con el proveedor anti-DDoS y los planes de DR / BCP.
Riesgo residual estimado	**Medio**

Nota. P × I = probabilidad × impacto; C = control (ver Tabla 33). Elaboración propia.

CA-11 · Acceso a funciones privilegiadas (BFLA)

Tabla 30

Detalle del caso de abuso CA-11 – Acceso a funciones privilegiadas (BFLA)

Amenaza vinculada	T13 – Elevation of Privilege (elemento(s): P5)

Riesgo inherente	**Alto (P×I = 8)**
Actor	Usuario malicioso autenticado
Objetivo del atacante	Ejecutar funciones privilegiadas (p. ej. aumentar límites).
Vector de ataque	Endpoints administrativos expuestos en la API pública.
Precondiciones	Rutas /admin accesibles; verificación de rol solo en el front-end.
Método de explotación	Modificar peticiones y forzar la navegación hacia endpoints de otros roles (BFLA).
Impacto esperado	Escalamiento de privilegios y fraude.
Control preventivo	RBAC en servidor con deny by default (C-04), lista blanca de rutas (C-12).
Control detectivo	Logs de accesos denegados y correlación en SIEM (C-21).
Acción correctiva	Corregir la validación, revertir los cambios realizados y revisar cuentas afectadas.
Riesgo residual estimado	**Bajo**

Nota. P × I = probabilidad × impacto; C = control (ver Tabla 33). Elaboración propia.

CA-12 · Abuso de privilegios en el backoffice

Tabla 31

Detalle del caso de abuso CA-12 – Abuso de privilegios en el backoffice

Amenaza vinculada	T14 – Elevation of Privilege (elemento(s): P8, E2)
Riesgo inherente	**Crítico (P×I = 12)**
Actor	Insider malicioso / atacante con cuenta de soporte comprometida
Objetivo del atacante	Cambiar contactos o dispositivos del cliente para sobrepasar el MFA y mover fondos.
Vector de ataque	Portal Backoffice (P8 → P4).
Precondiciones	Sin MFA para personal de soporte; privilegios amplios; sin aprobación dual.
Método de explotación	Cambiar el celular registrado, restablecer el MFA y luego tomar control de la cuenta.
Impacto esperado	Toma de cuentas a escala y fraude interno.
Control preventivo	PAM, MFA y aprobación dual para cambios sensibles (C-17).
Control detectivo	Reportes de cambios sensibles y analítica de comportamiento (C-21, C-20).
Acción correctiva	Revocar accesos, auditar casos atendidos, notificar a clientes afectados.
Riesgo residual estimado	**Medio**

Nota. P × I = probabilidad × impacto; C = control (ver Tabla 33). Elaboración propia.

CA-13 · Compromiso de dependencias de terceros y cadena de suministro

Tabla 32

Detalle del caso de abuso CA-13 – Compromiso de dependencias de terceros y cadena de suministro

Amenaza vinculada	T15 – Tampering (elemento(s): P1, P3, P5, P7)
Riesgo inherente	**Alto (P×I = 8)**
Actor	Atacante de cadena de suministro
Objetivo del atacante	Ejecutar código malicioso en la plataforma mediante una dependencia o el pipeline.
Vector de ataque	Librerías (npm / Maven / CocoaPods), CI/CD, imágenes de contenedor.
Precondiciones	Dependencias sin versión fija ni verificación; pipeline con controles débiles.

Método de explotación	Typosquatting, dependency confusion o compromiso de un mantenedor.
Impacto esperado	Backdoor, exfiltración de datos y compromiso total.
Control preventivo	SCA, SBOM y firma de artefactos (C-08), SAST / SCA en CI (C-24), cláusulas a proveedores (C-25).
Control detectivo	Alertas SCA y monitoreo de tráfico saliente anómalo.
Acción correctiva	Bloquear la versión, reconstruir artefactos, rotar secretos y revisar el alcance.
Riesgo residual estimado	**Medio**

Nota. P × I = probabilidad × impacto; C = control (ver Tabla 33). Elaboración propia.

7. Definición de controles de seguridad

7.1 Catálogo de controles

Tabla 33

Catálogo de controles de seguridad

ID	Categoría	Control	Descripción	Amenazas mitigadas
C-01	Aplicación	MFA resistente a phishing y step-up	FIDO2 / passkeys, TOTP o push con number matching; autenticación reforzada y confirmación de monto y destino en operaciones sensibles.	T01, T03, T17
C-02	Aplicación	Gestión segura de sesiones	Tokens de vida corta, rotación de refresh tokens, vinculación a dispositivo, invalidación en logout, cookies Secure / HttpOnly / SameSite.	T02, T28
C-03	Aplicación	Validación de entradas y minimización de datos	Validación por lista blanca, consultas parametrizadas, codificación de salida y exposición mínima de datos en respuestas y mensajes.	T03, T05, T08, T16, T28, T29
C-04	Aplicación	Autorización a nivel de objeto y de función	RBAC / ABAC aplicado en servidor, deny by default, pruebas automatizadas de autorización (BOLA / BFLA).	T08, T13
C-05	Aplicación	Cifrado en tránsito y en reposo	TLS 1.2+/1.3 con HSTS, certificate pinning en móvil, cifrado AES-256 en reposo y de campos sensibles.	T10, T11, T25, T26
C-06	Aplicación	Firma e integridad de transacciones	Firma digital / HMAC de la orden, nonce y sello de tiempo, evidencia de autorización para no repudio.	T03, T04, T06, T20
C-07	Aplicación	Protección de la app móvil	Ofuscación, detección de root / jailbreak, Play Integrity / App Attest, sin secretos embebidos, almacenamiento seguro.	T10, T11
C-08	Aplicación	Seguridad de la cadena de suministro	SCA (Dependency-Check), SBOM, versiones fijadas, firma de artefactos y pipeline CI/CD protegido.	T15
C-09	Aplicación	Almacenamiento seguro de credenciales	Argon2id / bcrypt con sal, verificación contra contraseñas filtradas, políticas de bloqueo progresivo.	T01, T21
C-10	APIs	OAuth 2.0 / OIDC	Authorization Code + PKCE, validación estricta de JWT (alg, iss, aud, exp), scopes mínimos.	T02, T10
C-11	APIs	Rate limiting y protección anti-bot / DDoS	Límites por usuario, IP y dispositivo; cuotas; protección volumétrica y de capa 7.	T01, T12
C-12	APIs	Seguridad en API Gateway	WAF, validación de esquemas, lista blanca de rutas y métodos, mTLS hacia servicios internos.	T02, T08, T12, T13, T24, T26
C-13	APIs	Idempotencia y anti-replay	Idempotency-Key, deduplicación en cola, ventanas de validez de mensajes.	T19, T20
C-14	Infraestructura	Segmentación de red	DMZ, zonas de aplicación / datos / integración, firewalls entre zonas, microsegmentación y principio Zero Trust.	T04, T26
C-15	Infraestructura	Hardening	Líneas base CIS, imágenes mínimas, deshabilitar endpoints y servicios de depuración, gestión de parches.	T24

ID	Categoría	Control	Descripción	Amenazas mitigadas
C-16	Infraestructura	Gestión de secretos y llaves	Bóveda / HSM, rotación automática, sin secretos en repositorios, escaneo de secretos.	T04, T09
C-17	Infraestructura	Acceso privilegiado y segregación de funciones	PAM, acceso Just-in-Time, MFA para administradores, aprobación dual (maker-checker), cuentas nominales.	T05, T07, T14, T23
C-18	Infraestructura	Resiliencia y continuidad	Alta disponibilidad, autoscaling, timeouts, circuit breakers, DR / BCP con pruebas periódicas.	T12, T18, T19
C-19	Infraestructura	Protección de bases de datos	Privilegios mínimos, separación de roles, monitoreo de actividad (DAM), cifrado, controles de integridad y tablas append-only.	T05, T07, T21
C-20	Monitoreo	Logging centralizado con integridad	Bitácoras centralizadas, inmutables (WORM / encadenamiento de hashes), sin datos personales en claro, sincronización de tiempo.	T06, T07, T14, T16, T22, T23, T27
C-21	Monitoreo	SIEM y casos de uso de detección	Correlación de eventos: credential stuffing, viaje imposible, enumeración, uso anómalo de llaves, cambios sensibles (UEBA).	T01, T05, T08, T09, T13, T14, T22, T30
C-22	Monitoreo	Alertamiento y respuesta a incidentes	Alertas priorizadas, runbooks, SOC, comunicación al cliente y a reguladores.	T12, T17, T27, T29
C-23	Monitoreo	Detección de fraude transaccional	Reglas y analítica / ML sobre montos, beneficiarios, dispositivo y comportamiento; conciliación automática.	T01, T03, T04, T30
C-24	Monitoreo	Pruebas de seguridad continuas	SAST (Semgrep), SCA, DAST (ZAP), escaneo de secretos y pruebas de penetración periódicas en el SSDLC.	T09, T15
C-25	Monitoreo	Gestión de seguridad de proveedores	Evaluación previa, cláusulas contractuales y SLA, acuerdos de procesamiento de datos, monitoreo de terceros.	T15, T17, T18, T25

Nota. C = control; T = amenaza (ver Tabla 9). Elaboración propia.

7.2 Relación amenaza – control

Tabla 34

Relación amenaza – control

ID	Amenaza	Riesgo	Controles asociados
T01	Toma de cuenta por credential stuffing, phishing o SIM swap	**Crítico**	C-01 MFA resistente a phishing y step-up · C-09 Almacenamiento seguro de credenciales · C-11 Rate limiting y protección anti-bot / DDoS · C-21 SIEM y casos de uso de detección · C-23 Detección de fraude transaccional
T03	Manipulación de monto o cuenta destino en la orden de transferencia	**Crítico**	C-06 Firma e integridad de transacciones · C-03 Validación de entradas y minimización de datos · C-01 MFA resistente a phishing y step-up · C-23 Detección de fraude transaccional
T08	Exposición masiva de datos por BOLA / IDOR o SQL injection	**Crítico**	C-04 Autorización a nivel de objeto y de función · C-03 Validación de entradas y minimización de datos · C-12 Seguridad en API Gateway · C-21 SIEM y casos de uso de detección
T14	Abuso de privilegios en el backoffice	**Crítico**	C-17 Acceso privilegiado y segregación de funciones · C-21 SIEM y casos de uso de detección · C-20 Logging centralizado con integridad
T06	Negación de operaciones por falta de no repudio	**Crítico**	C-06 Firma e integridad de transacciones · C-20 Logging centralizado con integridad
T10	Ingeniería inversa y almacenamiento inseguro en la app móvil	**Crítico**	C-07 Protección de la app móvil · C-05 Cifrado en tránsito y en reposo · C-10 OAuth 2.0 / OIDC
T04	Alteración o inyección de mensajes hacia ACH / Core	**Alto**	C-06 Firma e integridad de transacciones · C-14 Segmentación de red · C-16 Gestión de secretos y llaves · C-23 Detección de fraude transaccional
T05	Modificación no autorizada de saldos o transacciones en la BD	**Alto**	C-19 Protección de bases de datos · C-03 Validación de entradas y minimización de datos · C-17 Acceso privilegiado y segregación de funciones · C-21 SIEM y casos de uso de detección
T09	Compromiso de secretos y claves criptográficas	**Alto**	C-16 Gestión de secretos y llaves · C-24 Pruebas de seguridad continuas · C-21 SIEM y casos de uso de detección
T13	Acceso a funciones privilegiadas (BFLA)	**Alto**	C-04 Autorización a nivel de objeto y de función · C-12 Seguridad en API Gateway · C-21 SIEM y casos de uso de detección
T15	Compromiso de dependencias de terceros y cadena de suministro	**Alto**	C-08 Seguridad de la cadena de suministro · C-24 Pruebas de seguridad continuas · C-25 Gestión de seguridad de proveedores
T02	Token de acceso forjado o reutilizado	**Alto**	C-10 OAuth 2.0 / OIDC · C-02 Gestión segura de sesiones · C-12 Seguridad en API Gateway
T12	Denegación de servicio en login y transferencias	**Alto**	C-11 Rate limiting y protección anti-bot / DDoS · C-12 Seguridad en API Gateway · C-18 Resiliencia y continuidad · C-22 Alertamiento y respuesta a incidentes
T26	Suplantación del endpoint del Core / ACH	**Medio**	C-05 Cifrado en tránsito y en reposo · C-14 Segmentación de red · C-12 Seguridad en API Gateway
T07	Alteración o borrado de bitácoras de auditoría	**Medio**	C-20 Logging centralizado con integridad · C-19 Protección de bases de datos · C-17 Acceso privilegiado y segregación de funciones
T16	Datos personales en logs y mensajes de error	**Medio**	C-20 Logging centralizado con integridad · C-03 Validación de entradas y minimización de datos

ID	Amenaza	Riesgo	Controles asociados
T17	Suplantación del banco por SMS / correo (smishing)	**Medio**	C-25 Gestión de seguridad de proveedores · C-22 Alertamiento y respuesta a incidentes · C-01 MFA resistente a phishing y step-up
T18	Indisponibilidad del proveedor de SMS / Push	**Medio**	C-18 Resiliencia y continuidad · C-25 Gestión de seguridad de proveedores
T22	Cambios de dispositivo o credenciales sin trazabilidad	**Medio**	C-20 Logging centralizado con integridad · C-21 SIEM y casos de uso de detección
T23	Acciones de soporte sin identidad individual	**Medio**	C-17 Acceso privilegiado y segregación de funciones · C-20 Logging centralizado con integridad
T28	CSRF / clickjacking en la app web	**Medio**	C-02 Gestión segura de sesiones · C-03 Validación de entradas y minimización de datos
T30	Evasión del motor antifraude por fraccionamiento	**Medio**	C-23 Detección de fraude transaccional · C-21 SIEM y casos de uso de detección
T11	Intercepción de tráfico (MITM) por TLS débil	**Medio**	C-05 Cifrado en tránsito y en reposo · C-07 Protección de la app móvil
T19	Propagación de lentitud o caída del Core / ACH	**Medio**	C-18 Resiliencia y continuidad · C-13 Idempotencia y anti-replay
T20	Replay o duplicación de órdenes en la cola	**Medio**	C-13 Idempotencia y anti-replay · C-06 Firma e integridad de transacciones
T21	Exposición de credenciales por hashes débiles	**Medio**	C-09 Almacenamiento seguro de credenciales · C-19 Protección de bases de datos
T24	Endpoints de depuración o administración expuestos	**Medio**	C-15 Hardening · C-12 Seguridad en API Gateway
T25	Sobreexposición de datos personales hacia el proveedor KYC	**Medio**	C-25 Gestión de seguridad de proveedores · C-05 Cifrado en tránsito y en reposo
T27	Saturación del almacenamiento de bitácoras	**Bajo**	C-20 Logging centralizado con integridad · C-22 Alertamiento y respuesta a incidentes
T29	Plantillas de notificación con datos sensibles	**Bajo**	C-03 Validación de entradas y minimización de datos · C-22 Alertamiento y respuesta a incidentes

Nota. T = amenaza; C = control (ver Tabla 33). Elaboración propia.

7.3 Riesgos residuales

Estimación del riesgo tras implementar los controles de la sección 7.1. Los riesgos residuales Medio requieren aceptación formal del dueño del riesgo y revisión semestral.

Tabla 35

Riesgos residuales por caso de abuso

Caso	Amenaza	Inherente	Residual	Decisión
CA-01	T01 Toma de cuenta por credential stuffing, phishing o SIM swap	**Crítico**	**Medio**	Aceptar con monitoreo reforzado
CA-02	T02 Token de acceso forjado o reutilizado	**Alto**	**Bajo**	Aceptar
CA-03	T03 Manipulación de monto o cuenta destino en la orden de transferencia	**Crítico**	**Medio**	Aceptar con monitoreo reforzado
CA-04	T04 Alteración o inyección de mensajes hacia ACH / Core	**Alto**	**Bajo**	Aceptar
CA-05	T05 Modificación no autorizada de saldos o transacciones en la BD	**Alto**	**Bajo**	Aceptar

Caso	Amenaza	Inherente	Residual	Decisión
CA-06	T06 Negación de operaciones por falta de no repudio	**Crítico**	**Bajo**	Aceptar
CA-07	T08 Exposición masiva de datos por BOLA / IDOR o SQL injection	**Crítico**	**Medio**	Aceptar con monitoreo reforzado
CA-08	T09 Compromiso de secretos y claves criptográficas	**Alto**	**Bajo**	Aceptar
CA-09	T10 Ingeniería inversa y almacenamiento inseguro en la app móvil	**Crítico**	**Medio**	Aceptar con monitoreo reforzado
CA-10	T12 Denegación de servicio en login y transferencias	**Alto**	**Medio**	Aceptar con monitoreo reforzado
CA-11	T13 Acceso a funciones privilegiadas (BFLA)	**Alto**	**Bajo**	Aceptar
CA-12	T14 Abuso de privilegios en el backoffice	**Crítico**	**Medio**	Aceptar con monitoreo reforzado
CA-13	T15 Compromiso de dependencias de terceros y cadena de suministro	**Alto**	**Medio**	Aceptar con monitoreo reforzado

Nota. El riesgo residual es el estimado tras implementar los controles recomendados (Tabla 33). Elaboración propia.

8. Matriz de riesgos y remediación

Responsables expresados por rol. Las fechas objetivo parten del 07/10/2026; corto plazo = 0–3 meses, mediano = 3–6 meses, largo = 6–12 meses.

Tabla 36
Matriz de riesgos y remediación

ID	Riesgo identificado	Severidad	Responsable	Acción correctiva	Fecha objetivo	Plazo
T01	Toma de cuenta por credential stuffing, phishing o SIM swap	**Crítico**	CISO + Líder Backend	Implementar MFA resistente a phishing, anti-bot y verificación de contraseñas filtradas.	15/12/2026	Corto
T03	Manipulación de monto o cuenta destino en la orden de transferencia	**Crítico**	Líder de Arquitectura + Líder Backend	Firma de transacción (WYSIWYS) y revalidación server-side de la orden.	15/12/2026	Corto
T08	Exposición masiva de datos por BOLA / IDOR o SQL injection	**Crítico**	Líder Backend	Autorización por objeto en todos los endpoints, consultas parametrizadas y pruebas DAST.	15/12/2026	Corto
T14	Abuso de privilegios en el backoffice	**Crítico**	Jefe de Operaciones + CISO	PAM, MFA y aprobación dual para cambios sensibles en backoffice.	07/01/2027	Corto
T06	Negación de operaciones por falta de no repudio	**Crítico**	Arquitectura + Riesgo Operativo	Evidencia de autorización firmada y con sello de tiempo por operación.	28/02/2027	Mediano
T10	Ingeniería inversa y almacenamiento inseguro en la app móvil	**Crítico**	Líder de Desarrollo Móvil	Hardening de la app: pinning, attestation, ofuscación y eliminación de secretos.	28/02/2027	Mediano
T04	Alteración o inyección de mensajes hacia ACH / Core	**Alto**	Líder de Integración	mTLS y firma / MAC con HSM en integraciones Core y ACH.	31/03/2027	Mediano
T05	Modificación no autorizada de saldos o transacciones en la BD	**Alto**	DBA + CISO	Privilegios mínimos, DAM y conciliación contable automática.	28/02/2027	Mediano
T09	Compromiso de secretos y claves criptográficas	**Alto**	Jefe de Infraestructura	Migrar secretos a bóveda / HSM, escaneo de secretos en CI y rotación.	20/12/2026	Corto
T13	Acceso a funciones privilegiadas (BFLA)	**Alto**	Líder Backend	RBAC en servidor, deny by default y lista blanca de rutas.	20/12/2026	Corto
T15	Compromiso de dependencias de terceros y cadena de suministro	**Alto**	DevSecOps	SCA, SBOM, firma de artefactos y endurecimiento del pipeline.	31/03/2027	Mediano
T02	Token de acceso forjado o reutilizado	**Alto**	Líder Backend	Validación estricta de JWT en el gateway y rotación de llaves de firma.	20/12/2026	Corto
T12	Denegación de servicio en login y transferencias	**Alto**	Jefe de Infraestructura	Protección anti-DDoS, rate limiting y autoscaling.	07/01/2027	Corto

ID	Riesgo identificado	Severidad	Responsable	Acción correctiva	Fecha objetivo	Plazo
T26	Suplantación del endpoint del Core / ACH	**Medio**	Jefe de Redes	Validación estricta de certificados, DNS interno protegido y mTLS.	30/06/2027	Largo
T07	Alteración o borrado de bitácoras de auditoría	**Medio**	SOC + Infraestructura	Logs inmutables (WORM / hash chaining) y control de acceso a bitácoras.	30/06/2027	Largo
T16	Datos personales en logs y mensajes de error	**Medio**	Líder Backend	Redacción de datos personales en logs y errores genéricos al cliente.	28/02/2027	Mediano
T17	Suplantación del banco por SMS / correo (smishing)	**Medio**	Seguridad + Comunicaciones	DMARC / SPF / DKIM, sender ID registrado y campañas de concientización.	31/03/2027	Mediano
T18	Indisponibilidad del proveedor de SMS / Push	**Medio**	Arquitectura + Compras	Proveedor alterno y failover de OTP (push / TOTP); SLA contractual.	30/06/2027	Largo
T22	Cambios de dispositivo o credenciales sin trazabilidad	**Medio**	Líder Backend	Eventos de auditoría para cambios de dispositivo y credenciales.	28/02/2027	Mediano
T23	Acciones de soporte sin identidad individual	**Medio**	Jefe de Operaciones	Cuentas nominales y eliminación de cuentas compartidas.	28/02/2027	Mediano
T28	CSRF / clickjacking en la app web	**Medio**	Líder Frontend	Anti-CSRF, SameSite y frame-ancestors / CSP.	28/02/2027	Mediano
T30	Evasión del motor antifraude por fraccionamiento	**Medio**	Riesgo y Fraude	Afinar reglas y modelos antifraude; límites por perfil.	30/06/2027	Largo
T11	Intercepción de tráfico (MITM) por TLS débil	**Medio**	Jefe de Infraestructura	TLS 1.3 / suites seguras, HSTS y pinning.	28/02/2027	Mediano
T19	Propagación de lentitud o caída del Core / ACH	**Medio**	Líder de Integración	Timeouts, circuit breakers y colas de reintento controlado.	31/03/2027	Mediano
T20	Replay o duplicación de órdenes en la cola	**Medio**	Líder Backend	Idempotency-Key y deduplicación en la cola.	31/03/2027	Mediano
T21	Exposición de credenciales por hashes débiles	**Medio**	Líder Backend	Migrar a Argon2id con rehash progresivo.	30/06/2027	Largo
T24	Endpoints de depuración o administración expuestos	**Medio**	Jefe de Infraestructura	Deshabilitar endpoints de depuración y aplicar líneas base CIS.	20/12/2026	Corto
T25	Sobreexposición de datos personales hacia el proveedor KYC	**Medio**	Cumplimiento + Legal	Minimización de datos y acuerdo de procesamiento con el proveedor KYC.	30/09/2027	Largo
T27	Saturación del almacenamiento de bitácoras	**Bajo**	SOC	Cuotas y retención de logs; alertas de capacidad.	30/09/2027	Largo
T29	Plantillas de notificación con datos sensibles	**Bajo**	Producto + Seguridad	Enmascarar datos sensibles en notificaciones.	30/09/2027	Largo

Nota. Plazo: corto (0–3 meses), mediano (3–6 meses) y largo (6–12 meses). Elaboración propia.

9. Roadmap de mejoras

9.1 Corto plazo (0–3 meses)

Tabla 37

Plan de remediación a corto plazo (0–3 meses)

ID	Hallazgo y acción	Riesgo	Fecha
T01	**Toma de cuenta por credential stuffing, phishing o SIM swap.** Implementar MFA resistente a phishing, anti-bot y verificación de contraseñas filtradas.	**Crítico**	15/12/2026
T03	**Manipulación de monto o cuenta destino en la orden de transferencia.** Firma de transacción (WYSIWYS) y revalidación server-side de la orden.	**Crítico**	15/12/2026
T08	**Exposición masiva de datos por BOLA / IDOR o SQL injection.** Autorización por objeto en todos los endpoints, consultas parametrizadas y pruebas DAST.	**Crítico**	15/12/2026
T09	**Compromiso de secretos y claves criptográficas.** Migrar secretos a bóveda / HSM, escaneo de secretos en CI y rotación.	**Alto**	20/12/2026
T13	**Acceso a funciones privilegiadas (BFLA).** RBAC en servidor, deny by default y lista blanca de rutas.	**Alto**	20/12/2026
T02	**Token de acceso forjado o reutilizado.** Validación estricta de JWT en el gateway y rotación de llaves de firma.	**Alto**	20/12/2026
T24	**Endpoints de depuración o administración expuestos.** Deshabilitar endpoints de depuración y aplicar líneas base CIS.	**Medio**	20/12/2026
T14	**Abuso de privilegios en el backoffice.** PAM, MFA y aprobación dual para cambios sensibles en backoffice.	**Crítico**	07/01/2027
T12	**Denegación de servicio en login y transferencias.** Protección anti-DDoS, rate limiting y autoscaling.	**Alto**	07/01/2027

Nota. Las fechas son objetivos propuestos; la matriz completa se presenta en la Tabla 36. Elaboración propia.

9.2 Mediano plazo (3–6 meses)

Tabla 38

Plan de remediación a mediano plazo (3–6 meses)

ID	Hallazgo y acción	Riesgo	Fecha
T06	**Negación de operaciones por falta de no repudio.** Evidencia de autorización firmada y con sello de tiempo por operación.	**Crítico**	28/02/2027
T10	**Ingeniería inversa y almacenamiento inseguro en la app móvil.** Hardening de la app: pinning, attestation, ofuscación y eliminación de secretos.	**Crítico**	28/02/2027
T05	**Modificación no autorizada de saldos o transacciones en la BD.** Privilegios mínimos, DAM y conciliación contable automática.	**Alto**	28/02/2027
T16	**Datos personales en logs y mensajes de error.** Redacción de datos personales en logs y errores genéricos al cliente.	**Medio**	28/02/2027
T22	**Cambios de dispositivo o credenciales sin trazabilidad.** Eventos de auditoría para cambios de dispositivo y credenciales.	**Medio**	28/02/2027
T23	**Acciones de soporte sin identidad individual.** Cuentas nominales y eliminación de cuentas compartidas.	**Medio**	28/02/2027
T28	**CSRF / clickjacking en la app web.** Anti-CSRF, SameSite y frame-ancestors / CSP.	**Medio**	28/02/2027

ID	Hallazgo y acción	Riesgo	Fecha
T11	**Intercepción de tráfico (MITM) por TLS débil.** TLS 1.3 / suites seguras, HSTS y pinning.	**Medio**	28/02/2027
T04	**Alteración o inyección de mensajes hacia ACH / Core.** mTLS y firma / MAC con HSM en integraciones Core y ACH.	**Alto**	31/03/2027
T15	**Compromiso de dependencias de terceros y cadena de suministro.** SCA, SBOM, firma de artefactos y endurecimiento del pipeline.	**Alto**	31/03/2027
T17	**Suplantación del banco por SMS / correo (smishing).** DMARC / SPF / DKIM, sender ID registrado y campañas de concientización.	**Medio**	31/03/2027
T19	**Propagación de lentitud o caída del Core / ACH.** Timeouts, circuit breakers y colas de reintento controlado.	**Medio**	31/03/2027
T20	**Replay o duplicación de órdenes en la cola.** Idempotency-Key y deduplicación en la cola.	**Medio**	31/03/2027

Nota. Las fechas son objetivos propuestos; la matriz completa se presenta en la Tabla 36. Elaboración propia.

9.3 Largo plazo (6–12 meses)

Tabla 39

Plan de remediación a largo plazo (6–12 meses)

ID	Hallazgo y acción	Riesgo	Fecha
T07	**Alteración o borrado de bitácoras de auditoría.** Logs inmutables (WORM / hash chaining) y control de acceso a bitácoras.	**Medio**	30/06/2027
T18	**Indisponibilidad del proveedor de SMS / Push.** Proveedor alterno y failover de OTP (push / TOTP); SLA contractual.	**Medio**	30/06/2027
T26	**Suplantación del endpoint del Core / ACH.** Validación estricta de certificados, DNS interno protegido y mTLS.	**Medio**	30/06/2027
T30	**Evasión del motor antifraude por fraccionamiento.** Afinar reglas y modelos antifraude; límites por perfil.	**Medio**	30/06/2027
T21	**Exposición de credenciales por hashes débiles.** Migrar a Argon2id con rehash progresivo.	**Medio**	30/06/2027
T25	**Sobreexposición de datos personales hacia el proveedor KYC.** Minimización de datos y acuerdo de procesamiento con el proveedor KYC.	**Medio**	30/09/2027
T27	**Saturación del almacenamiento de bitácoras.** Cuotas y retención de logs; alertas de capacidad.	**Bajo**	30/09/2027
T29	**Plantillas de notificación con datos sensibles.** Enmascarar datos sensibles en notificaciones.	**Bajo**	30/09/2027

Nota. Las fechas son objetivos propuestos; la matriz completa se presenta en la Tabla 36. Elaboración propia.

9.4 Iniciativas transversales del SSDLC

- Mantener el modelo de amenazas en OWASP Threat Dragon como **artefacto oficial del SSDLC**, versionado en Git y revisado en cada cambio arquitectónico relevante o al menos cada seis meses.
- Incorporar la revisión del modelo de amenazas en la fase de diseño de cada épica que modifique flujos, fronteras de confianza o integraciones.

- Automatizar pruebas de seguridad en el pipeline (SAST con Semgrep, SCA con Dependency-Check, DAST con ZAP) y vincular los hallazgos a las amenazas del modelo.
- Medir el avance: porcentaje de amenazas Críticas / Altas mitigadas, tiempo medio de remediación y riesgos residuales aceptados.

10. Criterios de aceptación y control de evidencias

Tabla 40

Criterios de aceptación y control de evidencias

Criterio / entregable	Evidencia	Estado
Inventario de componentes y de activos	Secciones 2.3 y 2.4	Elaborado en este informe
Arquitectura lógica validada	Sección 2.2 y registro 4.4	Elaborado en este informe
DFD Nivel 0 y Nivel 1 (aprobados)	Secciones 3.2 y 3.3; capturas de Threat Dragon	Elaborado en este informe
Trust Boundaries identificados y documentados	Sección 3.4	Elaborado en este informe
DFD Nivel 2	Sección 3.5; captura de Threat Dragon	Elaborado en este informe
Proyecto Threat Dragon (.json) y versionado	Repositorio Git con tags v1.0 / v1.1	Elaborado en este informe URL; https://github.com/rblancolll/threat-model-banca-digital.git
Lista de amenazas generada por Threat Dragon	Capturas de la sección 4.1	Elaborado en este informe
Matriz STRIDE consolidada	Sección 4.3	Elaborado en este informe
Registro de validación técnica	Sección 4.4	Elaborado en este informe
Matriz de riesgos, ranking y Top 10	Secciones 5.2 a 5.4	Elaborado en este informe
Casos de abuso para amenazas críticas y altas	Sección 6	Elaborado en este informe
Controles de mitigación y relación amenaza-control	Sección 7	Elaborado en este informe
Riesgos residuales	Sección 7.3	Elaborado en este informe
Matriz de remediación y roadmap	Secciones 8 y 9	Elaborado en este informe

Nota. Las secciones indicadas corresponden a este informe. Elaboración propia.

11. Conclusiones

El modelado temprano de amenazas realizado mediante OWASP Threat Dragon permitió identificar un total de 30 amenazas en la arquitectura, priorizando 13 de ellas con severidad crítica o alta antes de la fase de implementación. Este análisis demostró que las fronteras de confianza TB-1 (Internet), TB-6 (Integración bancaria) y TB-7 (Terceros) representan las superficies de mayor riesgo, por lo que concentran el esfuerzo de seguridad en requerir autenticación fuerte, integridad de transacciones y firma de mensajes.

Asimismo, se determinó que los controles preventivos con mayor retorno de inversión para la plataforma son la autenticación resistente a phishing, la autorización a nivel de objeto y función, y el control estricto de accesos privilegiados en el backoffice. Finalmente, para garantizar su efectividad integral, se concluye que este modelo debe mantenerse como un artefacto vivo dentro del Ciclo de Vida de Desarrollo Seguro (SSDLC), actualizándose ante cualquier cambio de arquitectura, integraciones con terceros o nuevas amenazas del sector financiero.

12. Referencias

Microsoft. (2024). Security Development Lifecycle — Threat Modeling. https://www.microsoft.com/securityengineering/sdl/threatmodeling

National Institute of Standards and Technology. (2012). Guide for Conducting Risk Assessments (NIST SP 800-30 Rev. 1). https://csrc.nist.gov/pubs/sp/800/30/r1/final

OWASP Foundation. (2023). OWASP API Security Top 10 – 2023. https://owasp.org/API-Security/

OWASP Foundation. (2021). OWASP Top 10:2021. https://owasp.org/Top10/

OWASP Foundation. (2024). OWASP Cheat Sheet Series. https://cheatsheetseries.owasp.org/

OWASP Foundation. (2024). OWASP Threat Dragon. https://owasp.org/www-project-threat-dragon/

OWASP Foundation. (2021). Application Security Verification Standard (ASVS) 4.0.3. https://owasp.org/www-project-application-security-verification-standard/

Shostack, A. (2014). Threat Modeling: Designing for Security. Wiley.

Superintendencia de Bancos de Guatemala. (2021). Reglamento para la Administración del Riesgo Tecnológico (Resolución JM-104-2021).

Universidad Mariano Gálvez de Guatemala. (2026). Seguridad en Aplicaciones, Semana 2: Modelado de amenazas — STRIDE, DFD y priorización [Presentación]. MASI 093-013.